
**Information technology — Security
techniques — Information security
risk management**

*Technologies de l'information — Techniques de sécurité — Gestion
des risques liés à la sécurité de l'information*





COPYRIGHT PROTECTED DOCUMENT

© ISO/IEC 2018

All rights reserved. Unless otherwise specified, or required in the context of its implementation, no part of this publication may be reproduced or utilized otherwise in any form or by any means, electronic or mechanical, including photocopying, or posting on the internet or an intranet, without prior written permission. Permission can be requested from either ISO at the address below or ISO's member body in the country of the requester.

ISO copyright office
CP 401 • Ch. de Blandonnet 8
CH-1214 Vernier, Geneva
Phone: +41 22 749 01 11
Fax: +41 22 749 09 47
Email: copyright@iso.org
Website: www.iso.org

Published in Switzerland

Contents

Page

Foreword	v
Introduction	vi
1 Scope	1
2 Normative references	1
3 Terms and definitions	1
4 Structure of this document	1
5 Background	2
6 Overview of the information security risk management process	3
7 Context establishment	5
7.1 General considerations	5
7.2 Basic criteria	6
7.2.1 Risk management approach	6
7.2.2 Risk evaluation criteria	6
7.2.3 Impact criteria	6
7.2.4 Risk acceptance criteria	7
7.3 Scope and boundaries	7
7.4 Organization for information security risk management	8
8 Information security risk assessment	8
8.1 General description of information security risk assessment	8
8.2 Risk identification	9
8.2.1 Introduction to risk identification	9
8.2.2 Identification of assets	9
8.2.3 Identification of threats	10
8.2.4 Identification of existing controls	10
8.2.5 Identification of vulnerabilities	11
8.2.6 Identification of consequences	12
8.3 Risk analysis	12
8.3.1 Risk analysis methodologies	12
8.3.2 Assessment of consequences	13
8.3.3 Assessment of incident likelihood	14
8.3.4 Level of risk determination	15
8.4 Risk evaluation	15
9 Information security risk treatment	16
9.1 General description of risk treatment	16
9.2 Risk modification	18
9.3 Risk retention	19
9.4 Risk avoidance	19
9.5 Risk sharing	19
10 Information security risk acceptance	20
11 Information security risk communication and consultation	20
12 Information security risk monitoring and review	21
12.1 Monitoring and review of risk factors	21
12.2 Risk management monitoring, review and improvement	22
Annex A (informative) Defining the scope and boundaries of the information security risk management process	24
Annex B (informative) Identification and valuation of assets and impact assessment	28
Annex C (informative) Examples of typical threats	37

Annex D (informative) Vulnerabilities and methods for vulnerability assessment	41
Annex E (informative) Information security risk assessment approaches	45
Annex F (informative) Constraints for risk modification	51
Bibliography	53

Foreword

ISO (the International Organization for Standardization) and IEC (the International Electrotechnical Commission) form the specialized system for worldwide standardization. National bodies that are members of ISO or IEC participate in the development of International Standards through technical committees established by the respective organization to deal with particular fields of technical activity. ISO and IEC technical committees collaborate in fields of mutual interest. Other international organizations, governmental and non-governmental, in liaison with ISO and IEC, also take part in the work. In the field of information technology, ISO and IEC have established a joint technical committee, ISO/IEC JTC 1.

The procedures used to develop this document and those intended for its further maintenance are described in the ISO/IEC Directives, Part 1. In particular the different approval criteria needed for the different types of document should be noted. This document was drafted in accordance with the editorial rules of the ISO/IEC Directives, Part 2 (see www.iso.org/directives).

Attention is drawn to the possibility that some of the elements of this document may be the subject of patent rights. ISO and IEC shall not be held responsible for identifying any or all such patent rights. Details of any patent rights identified during the development of the document will be in the Introduction and/or on the ISO list of patent declarations received (see www.iso.org/patents).

Any trade name used in this document is information given for the convenience of users and does not constitute an endorsement.

For an explanation on the voluntary nature of standards, the meaning of ISO specific terms and expressions related to conformity assessment, as well as information about ISO's adherence to the World Trade Organization (WTO) principles in the Technical Barriers to Trade (TBT) see the following URL: www.iso.org/iso/foreword.html.

This document was prepared by Technical Committee ISO/IEC JTC 1, *Information technology*, Subcommittee SC 27, *IT Security techniques*.

Any feedback or questions on this document should be directed to the user's national standards body. A complete listing of these bodies can be found at www.iso.org/members.html.

This third edition cancels and replaces the second edition (ISO/IEC 27005:2011) which has been technically revised. The main changes from the previous edition are as follows:

- all direct references to the ISO/IEC 27001:2005 have been removed;
- clear information has been added that this document does not contain direct guidance on the implementation of the ISMS requirements specified in ISO/IEC 27001 (see Introduction);
- ISO/IEC 27001:2005 has been removed from [Clause 2](#);
- ISO/IEC 27001 has been added to the Bibliography;
- Annex G and all references to it have been removed;
- editorial changes have been made accordingly.

Introduction

This document provides guidelines for information security risk management in an organization. However, this document does not provide any specific method for information security risk management. It is up to the organization to define their approach to risk management, depending for example on the scope of an information security management system (ISMS), context of risk management, or industry sector. A number of existing methodologies can be used under the framework described in this document to implement the requirements of an ISMS. This document is based on the asset, threat and vulnerability risk identification method that is no longer required by ISO/IEC 27001. There are some other approaches that can be used.

This document does not contain direct guidance on the implementation of the ISMS requirements given in ISO/IEC 27001.

This document is relevant to managers and staff concerned with information security risk management within an organization and, where appropriate, external parties supporting such activities.

Information technology — Security techniques — Information security risk management

1 Scope

This document provides guidelines for information security risk management.

This document supports the general concepts specified in ISO/IEC 27001 and is designed to assist the satisfactory implementation of information security based on a risk management approach.

Knowledge of the concepts, models, processes and terminologies described in ISO/IEC 27001 and ISO/IEC 27002 is important for a complete understanding of this document.

This document is applicable to all types of organizations (e.g. commercial enterprises, government agencies, non-profit organizations) which intend to manage risks that can compromise the organization's information security.

2 Normative references

The following documents are referred to in the text in such a way that some or all of their content constitutes requirements of this document. For dated references, only the edition cited applies. For undated references, the latest edition of the referenced document (including any amendments) applies.

ISO/IEC 27000, *Information technology — Security techniques — Information security management systems — Overview and vocabulary*

3 Terms and definitions

For the purposes of this document, the terms and definitions given in ISO/IEC 27000 and the following apply.

ISO and IEC maintain terminological databases for use in standardization at the following addresses:

- ISO Online browsing platform: available at <https://www.iso.org/obp>
- IEC Electropedia: available at <http://www.electropedia.org/>

4 Structure of this document

This document contains the description of the information security risk management process and its activities.

The background information is provided in [Clause 5](#).

A general overview of the information security risk management process is given in [Clause 6](#).

All information security risk management activities as presented in [Clause 6](#) are subsequently described in the following clauses:

- context establishment in [Clause 7](#);
- risk assessment in [Clause 8](#);
- risk treatment in [Clause 9](#);

- risk acceptance in [Clause 10](#);
- risk communication in [Clause 11](#);
- risk monitoring and review in [Clause 12](#).

Additional information for information security risk management activities is presented in the annexes. The context establishment is supported by [Annex A](#) (Defining the scope and boundaries of the information security risk management process). Identification and valuation of assets and impact assessments are discussed in [Annex B](#). [Annex C](#) gives examples of typical threats and [Annex D](#) discusses vulnerabilities and methods for vulnerability assessment. Examples of information security risk assessment approaches are presented in [Annex E](#).

Constraints for risk modification are presented in [Annex E](#).

All risk management activities as presented from [Clause 7](#) to [Clause 12](#) are structured as follows:

Input: Identifies any required information to perform the activity.

Action: Describes the activity.

Implementation guidance: Provides guidance on performing the action. Some of this guidance may not be suitable in all cases and so other ways of performing the action may be more appropriate.

Output: Identifies any information derived after performing the activity.

5 Background

A systematic approach to information security risk management is necessary to identify organizational needs regarding information security requirements and to create an effective information security management system (ISMS). This approach should be suitable for the organization's environment and, in particular, should be aligned with overall enterprise risk management. Security efforts should address risks in an effective and timely manner where and when they are needed. Information security risk management should be an integral part of all information security management activities and should be applied both to the implementation and the ongoing operation of an ISMS.

Information security risk management should be a continual process. The process should establish the external and internal context, assess the risks and treat the risks using a risk treatment plan to implement the recommendations and decisions. Risk management analyses what can happen and what the possible consequences can be, before deciding what should be done and when, to reduce the risk to an acceptable level.

Information security risk management should contribute to the following:

- risks being identified;
- risks being assessed in terms of their consequences to the business and the likelihood of their occurrence;
- the likelihood and consequences of these risks being communicated and understood;
- priority order for risk treatment being established;
- priority for actions to reduce risks occurring;
- stakeholders being involved when risk management decisions are made and kept informed of the risk management status;
- effectiveness of risk treatment monitoring;
- risks and the risk management process being monitored and reviewed regularly;

- information being captured to improve the risk management approach;
- managers and staff being educated about the risks and the actions taken to mitigate them.

The information security risk management process can be applied to the organization as a whole, any discrete part of the organization (e.g. a department, a physical location, a service), any information system, existing or planned or particular aspects of control (e.g. business continuity planning).

6 Overview of the information security risk management process

A high level view of the risk management process is specified in ISO 31000 and shown in [Figure 1](#).

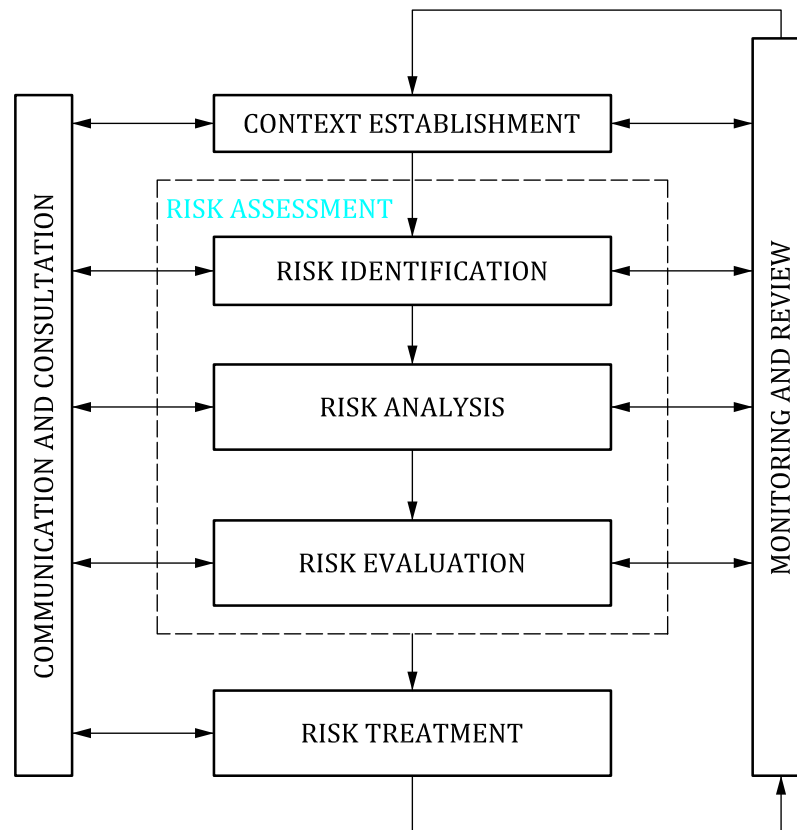


Figure 1 — The risk management process

[Figure 2](#) shows how this document applies this risk management process.

The information security risk management process consists of context establishment ([Clause 7](#)), risk assessment ([Clause 8](#)), risk treatment ([Clause 9](#)), risk acceptance ([Clause 10](#)), risk communication and consultation ([Clause 11](#)), and risk monitoring and review ([Clause 12](#)).

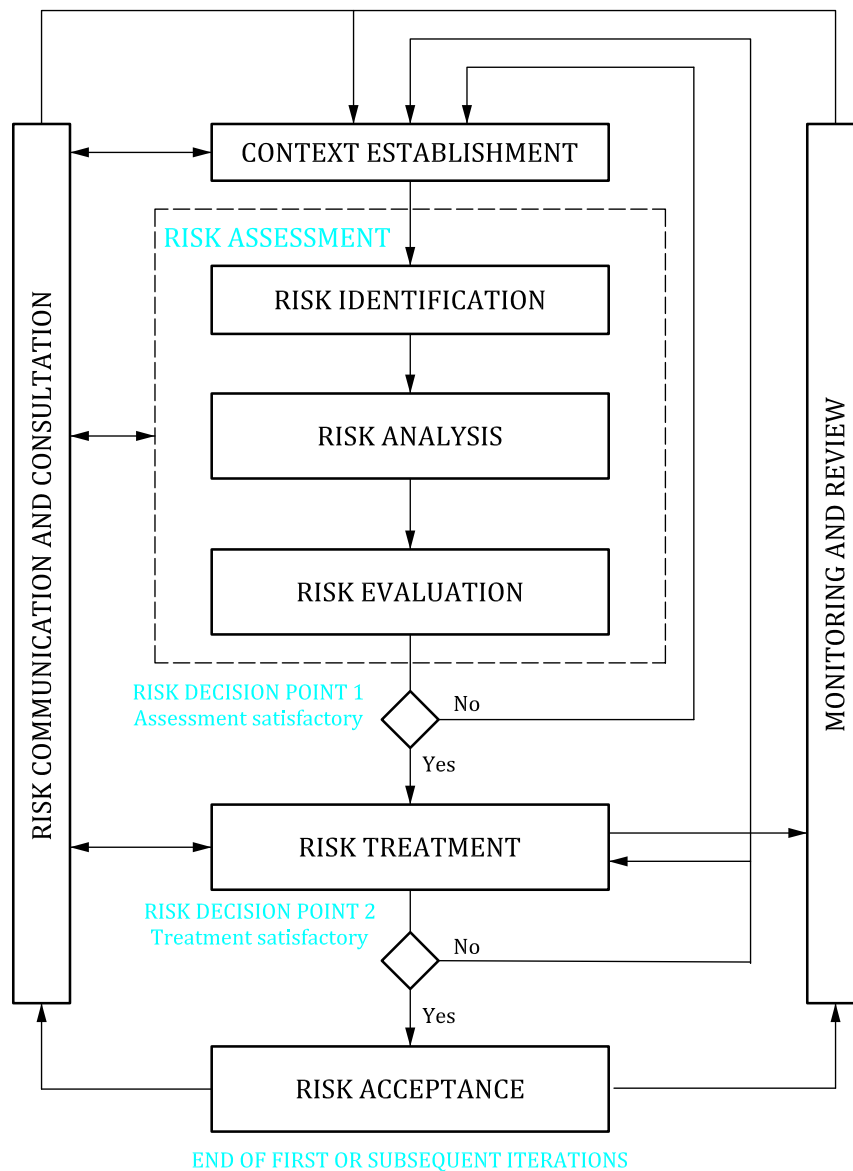


Figure 2 — Illustration of an information security risk management process

As [Figure 2](#) illustrates, the information security risk management process can be iterative for risk assessment and/or risk treatment activities. An iterative approach to conducting risk assessment can increase depth and detail of the assessment at each iteration. The iterative approach provides a good balance between minimizing the time and effort spent in identifying controls, while still ensuring that high risks are appropriately assessed.

The context is established first. Then, a risk assessment is conducted. If this provides sufficient information to effectively determine the actions required to modify the risks to an acceptable level, then the task is complete and the risk treatment follows. If the information is insufficient, another iteration of the risk assessment with revised context (e.g. risk evaluation criteria, risk acceptance criteria or impact criteria) is conducted, possibly on limited parts of the total scope (see [Figure 2](#), Risk Decision Point 1).

The effectiveness of the risk treatment depends on the results of the risk assessment.

Note that risk treatment involves a cyclical process of:

- assessing a risk treatment;

- deciding whether residual risk levels are acceptable;
- generating a new risk treatment if risk levels are not acceptable; and
- assessing the effectiveness of that treatment.

It is possible that the risk treatment does not immediately lead to an acceptable level of residual risk. In this situation, another iteration of the risk assessment with changed context parameters (e.g. risk assessment, risk acceptance or impact criteria), if necessary, can be required, followed by further risk treatment (see [Figure 2](#), Risk Decision Point 2).

The risk acceptance activity has to ensure residual risks are explicitly accepted by the managers of the organization. This is especially important in a situation where the implementation of controls is omitted or postponed, e.g. due to cost.

During the whole information security risk management process, it is important that risks and their treatment are communicated to the appropriate managers and operational staff. Even before the treatment of the risks, information about identified risks can be very valuable to manage incidents and can help to reduce potential damage. Awareness by managers and staff of the risks, the nature of the controls in place to mitigate the risks and the areas of concern to the organization assist in dealing with incidents and unexpected events in the most effective manner. The detailed results of every activity of the information security risk management process and from the two risk decision points should be documented.

ISO/IEC 27001 specifies that the controls implemented within the scope, boundaries and context of the ISMS need to be risk-based. The application of an information security risk management process can satisfy this requirement. There are many approaches by which controls can be determined to implement the risk treatment options chosen.

The organization should establish, implement and maintain a procedure to identify the legal requirements applicable to:

- the selection of criteria for risk evaluation ([7.2.2](#)), risk impact ([7.2.3](#)) and risk acceptance ([7.2.4](#));
- the definition of the scope and boundaries of information security risk management ([7.3](#) and [A.2](#));
- risk evaluation ([8.4](#));
- risk treatment of ([9.1](#)) and the implementation of risk reduction plans ([9.2](#) and [Annex F](#));
- the monitoring, review and improvement of risk management ([12.2](#));
- asset identification ([B.1.3](#)) and asset valuation ([B.2.3](#)); and
- risk estimation (see examples in [E.2.1](#)).

7 Context establishment

7.1 General considerations

Input: All information about the organization relevant to the information security risk management context establishment.

Action: The external and internal context for information security risk management should be established, which involves setting the basic criteria necessary for information security risk management ([7.2](#)), defining the scope and boundaries ([7.3](#)), and establishing an appropriate organization operating the information security risk management ([7.4](#)).

Implementation guidance:

It is essential to determine the purpose of the information security risk management as this affects the overall process and the context establishment in particular. This purpose can be:

- supporting an ISMS;
- legal compliance and evidence of due diligence;
- preparation of a business continuity plan;
- preparation of an incident response plan; and
- description of the information security requirements for a product, a service or a mechanism.

Implementation guidance for context establishment elements needed to support an ISMS is further discussed in [7.2](#), [7.3](#) and [7.4](#) below.

Output: The specification of basic criteria, the scope and boundaries, and the organization for the information security risk management process.

7.2 Basic criteria

7.2.1 Risk management approach

Depending on the scope and objectives of the risk management, different approaches can be applied. The approach can also be different for each iteration.

An appropriate risk management approach should be selected or developed that addresses basic criteria such as: risk evaluation criteria, impact criteria, risk acceptance criteria.

Additionally, the organization should assess whether necessary resources are available to:

- perform risk assessment and establish a risk treatment plan;
- define and implement policies and procedures, including implementation of the controls selected;
- monitor controls; and
- monitor the information security risk management process.

7.2.2 Risk evaluation criteria

Risk evaluation criteria should be developed for evaluating the organization's information security risk considering the following:

- the strategic value of the business information process;
- the criticality of the information assets involved;
- operational and business importance of availability, confidentiality and integrity;
- stakeholders' expectations and perceptions, and negative consequences for goodwill and reputation;

Additionally, risk evaluation criteria can be used to specify priorities for risk treatment.

7.2.3 Impact criteria

NOTE ISO 31000 uses a concept of "consequence criteria" instead of "impact criteria".

Impact criteria should be developed and specified in terms of the degree of damage or costs to the organization caused by an information security event considering the following:

- level of classification of the impacted information asset;

- breaches of information security (e.g. loss of confidentiality, integrity and availability);
- impaired operations (internal or third parties);
- loss of business and financial value;
- disruption of plans and deadlines;
- damage of reputation;

7.2.4 Risk acceptance criteria

Risk acceptance criteria should be developed and specified. Risk acceptance criteria often depend on the organization's policies, goals, objectives and the interests of stakeholders.

An organization should define its own scales for levels of risk acceptance. The following should be considered during development:

- risk acceptance criteria can include multiple thresholds, with a desired target level of risk, but provision for senior managers to accept risks above this level under defined circumstances;
- risk acceptance criteria can be expressed as the ratio of estimated profit (or other business benefit) to the estimated risk;
- different risk acceptance criteria can apply to different classes of risk;
- risk acceptance criteria can include requirements for future additional treatment, e.g. a risk can be accepted if there is approval and commitment to take action to reduce it to an acceptable level within a defined time period.

Risk acceptance criteria can differ according to how long the risk is expected to exist, e.g. the risk can be associated with a temporary or short-term activity. Risk acceptance criteria should be set up considering the following:

- business criteria;
- operations;
- technology;
- finance;
- social and humanitarian factors.

More information can be found in [Annex A](#).

7.3 Scope and boundaries

The organization should define the scope and boundaries of information security risk management.

The scope of the information security risk management process needs to be defined to ensure that all relevant assets are taken into account in the risk assessment. In addition, the boundaries need to be identified to address those risks that can arise through these boundaries.

Information about the organization should be collected to determine the environment it operates in and its relevance to the information security risk management process.

When defining the scope and boundaries, the organization should consider the following information:

- the organization's strategic business objectives, strategies and policies;
- business processes;

- the organization's functions and structure;
- the organization's information security policy;
- the organization's overall approach to risk management;
- information assets;
- locations of the organization and their geographical characteristics;
- constraints affecting the organization;
- expectation of stakeholders;
- socio-cultural environment;
- interfaces (i.e. information exchange with the environment).

Additionally, the organization should provide justification for any exclusion from the scope.

Examples of the risk management scope may be an IT application, IT infrastructure, a business process, or a defined part of an organization.

Further information can be found in [Annex A](#).

7.4 Organization for information security risk management

The organization and responsibilities for the information security risk management process should be set up and maintained. The following are the main roles and responsibilities of this organization:

- development of the information security risk management process suitable for the organization;
- identification and analysis of the stakeholders;
- definition of roles and responsibilities of all parties both internal and external to the organization;
- establishment of the required relationships between the organization and stakeholders, as well as interfaces to the organization's high-level risk management functions (e.g. operational risk management), as well as interfaces to other relevant projects or activities;
- definition of decision escalation paths;
- specification of records to be kept.

This organization should be approved by the appropriate managers of the organization.

8 Information security risk assessment

8.1 General description of information security risk assessment

Input: Basic criteria, the scope and boundaries, and the organization for the information security risk management process being established.

Action: Risks should be identified, quantified or qualitatively described, and prioritized against risk evaluation criteria and objectives relevant to the organization.

Implementation guidance:

A risk is a combination of the consequences that would follow from the occurrence of an unwanted event and the likelihood of the occurrence of the event. Risk assessment quantifies or qualitatively describes the risk and enables managers to prioritize risks according to their perceived seriousness or other established criteria.

Risk assessment consists of the following activities:

- risk identification (8.2);
- risk analysis (8.3);
- risk evaluation (8.4).

Risk assessment determines the value of the information assets, identifies the applicable threats and vulnerabilities that exist (or can exist), identifies the existing controls and their effect on the risk identified, determines the potential consequences and, finally, prioritizes the derived risks and ranks them against the risk evaluation criteria set in the context establishment.

Risk assessment is often conducted in two (or more) iterations. First, a high level assessment is carried out to identify potentially high risks that warrant further assessment. The next iteration can involve further in-depth consideration of potentially high risks revealed in the initial iteration. Where this provides insufficient information to assess the risk, then further detailed analyses are conducted, probably on parts of the total scope, and possibly using a different method.

It is up to the organization to select its own approach to risk assessment based on the objectives and the aim of the risk assessment.

Discussion on information security risk assessment approaches can be found in [Annex E](#).

Output: A list of assessed risks prioritized according to risk evaluation criteria.

8.2 Risk identification

8.2.1 Introduction to risk identification

The purpose of risk identification is to determine what can happen to cause a potential loss, and to gain insight into how, where and why the loss can happen. The steps described in the following subclauses should collect input data for the risk analysis activity.

Risk identification should include risks whether or not their source is under the control of the organization, even though the risk source or cause is perhaps not evident.

NOTE Activities described in subsequent subclauses can be conducted in a different order depending on the methodology applied.

8.2.2 Identification of assets

Input: Scope and boundaries for the risk assessment to be conducted, list of constituents with owners, location, function, etc.

Action: The assets within the established scope should be identified.

Implementation guidance:

An asset is anything that has value to the organization and which, therefore, requires protection. For the identification of assets, it should be borne in mind that an information system consists of more than hardware and software.

Asset identification should be performed at a suitable level of detail that provides sufficient information for the risk assessment. The level of detail used on the asset identification influences the overall amount of information collected during the risk assessment. The level can be refined in further iterations of the risk assessment.

An asset owner should be identified for each asset, to provide responsibility and accountability for the asset. The asset owner perhaps does not have property rights to the asset, but has responsibility for its

production, development, maintenance, use and security as appropriate. The asset owner is often the most suitable person to determine the asset's value to the organization (see [8.3.2](#) for asset valuation).

The review boundary is the perimeter of assets of the organization defined to be managed by the information security risk management process.

More information on the identification and valuation of assets as related to information security can be found in [Annex B](#).

Output: A list of assets to be risk-managed, and a list of business processes related to assets and their relevance.

8.2.3 Identification of threats

Input: Information on threats obtained from incident reviewing, asset owners, users and other sources, including external threat catalogues.

Action: Threats and their sources should be identified.

Implementation guidance:

A threat has the potential to harm assets such as information, processes and systems and, therefore, organizations. Threats can be of natural or human origin, and can be accidental or deliberate. Both accidental and deliberate threat sources should be identified. A threat can arise from within or from outside the organization. Threats should be identified generically and by type (e.g. unauthorized actions, physical damage, technical failures); then, where appropriate, individual threats within the generic class identified. This means no threat is overlooked, including the unexpected, but the volume of work required is limited.

Some threats can affect more than one asset. In such cases, they can cause different impacts depending on which assets are affected.

Input to the threat identification and estimation of the likelihood of occurrence (see [8.3.3](#)) can be obtained from the asset owners or users, from human resources staff, from facility management and information security specialists, physical security experts, legal department and other relevant organizations including legal bodies, weather authorities, insurance companies and government authorities. Aspects of environment and culture should also be considered when addressing threats.

Internal experience from incidents and past threat assessments should be considered in the current assessment. It can be worthwhile to consult other threat catalogues (maybe specific to an organization or business) to complete the list of generic threats, where relevant. Threat catalogues and statistics are available from industry bodies, governments, legal bodies, insurance companies, etc.

When using threat catalogues, or the results of earlier threat assessments, one should be aware that there is continual change of relevant threats, especially if the business environment or information systems change.

More information on threat types can be found in [Annex C](#).

Output: A list of threats with the identification of threat type and source.

8.2.4 Identification of existing controls

Input: Documentation of controls, risk treatment implementation plans.

Action: Existing and planned controls should be identified.

Implementation guidance:

Identification of existing controls should be made to avoid unnecessary work or cost, e.g. in the duplication of controls. In addition, while identifying the existing controls, a check should be made to

ensure that the controls are working correctly — a reference to already existing ISMS audit reports should limit the time expended in this task. If a control does not work as expected, this can cause vulnerabilities. Consideration should be given to the situation where a selected control (or strategy) fails in operation and, therefore, complementary controls are required to address the identified risk effectively.

Controls that are planned to be implemented according to the risk treatment implementation plans should be considered in the same way like those already implemented.

An existing or planned control can be identified as ineffective, or not sufficient, or not justified. If not justified or not sufficient, the control should be checked to determine whether it should be removed, replaced by another, more suitable control, or whether it should stay in place, for example, for cost reasons.

For the identification of existing or planned controls, the following activities can be helpful:

- reviewing documents containing information about the controls (for example, risk treatment implementation plans) if the processes of information security management are well documented all existing or planned controls and the status of their implementation should be available;
- checking with the people responsible for information security (e.g. information security officer and information system security officer, building manager or operations manager) and the users as to which controls are really implemented for the information process or information system under consideration;
- conducting an on-site review of the physical controls, comparing those implemented with the list of what controls should be there, and checking those implemented as to whether they are working correctly and effectively;
- reviewing results of audits.

Output: A list of all existing and planned controls, their implementation and usage status.

8.2.5 Identification of vulnerabilities

Input: A list of known threats, lists of assets and existing controls.

Action: Vulnerabilities that can be exploited by threats to cause harm to assets or to the organization should be identified.

Implementation guidance:

Vulnerabilities can be identified in following areas:

- organization;
- processes and procedures;
- management routines;
- personnel;
- physical environment;
- information system configuration;
- hardware, software or communications equipment;
- dependence on external parties.

The presence of a vulnerability does not cause harm in itself, as there needs to be a threat present to exploit it. A vulnerability that has no corresponding threat may not require the implementation of a control, but should be recognized and monitored for changes. It should be noted that an incorrectly

implemented or malfunctioning control or control being used incorrectly can itself be a vulnerability. A control can be effective or ineffective depending on the environment in which it operates. Conversely, a threat that does not have a corresponding vulnerability may not result in a risk.

Vulnerabilities can be related to properties of the asset that can be used in a way, or for a purpose, other than that intended when the asset was purchased or made. Vulnerabilities arising from different sources need to be considered, for example, those intrinsic or extrinsic to the asset.

Examples of vulnerabilities and methods for vulnerability assessment can be found in [Annex D](#).

Output: A list of vulnerabilities in relation to assets, threats and controls; a list of vulnerabilities that do not relate to any identified threat for review.

8.2.6 Identification of consequences

Input: A list of assets, a list of business processes, and a list of threats and vulnerabilities, where appropriate, related to assets and their relevance.

Action: The consequences that losses of confidentiality, integrity and availability may have on the assets should be identified.

Implementation guidance:

A consequence can be loss of effectiveness, adverse operating conditions, loss of business, reputation, damage, etc.

This activity identifies the damage or consequences to the organization that can be caused by an incident scenario. An incident scenario is the description of a threat exploiting a certain vulnerability or set of vulnerabilities in an information security incident. The impact of the incident scenarios is to be determined considering impact criteria defined during the context establishment activity. It can affect one or more assets or part of an asset. Thus, assets can have assigned values both for their financial cost and because of the business consequences if they are damaged or compromised. Consequences can be of a temporary nature or permanent as in the case of the destruction of an asset.

Organizations should identify the operational consequences of incident scenarios in terms of (but not limited to):

- Investigation and repair time;
- (work)time lost;
- opportunity lost;
- health and safety;
- financial cost of specific skills to repair the damage; and
- image reputation and goodwill.

Details on assessment of technical vulnerabilities can be found in [B.3](#).

Output: A list of incident scenarios with their consequences related to assets and business processes.

8.3 Risk analysis

8.3.1 Risk analysis methodologies

Risk analysis can be undertaken in varying degrees of detail depending on the criticality of assets, extent of vulnerabilities known, and prior incidents involving in the organization. A risk analysis methodology can be qualitative or quantitative, or a combination of these, depending on the circumstances. In practice, qualitative analysis is often used first to obtain a general indication of the level of risk and to

reveal the major risks. Later, it can be necessary to undertake more specific or quantitative analysis on the major risks because it is usually less complex and less expensive to perform qualitative than quantitative analysis.

The form of analysis should be consistent with the risk evaluation criteria developed as part of establishing the context.

Further details of analysis methodologies are described below:

a) Qualitative risk analysis:

Qualitative risk analysis uses a scale of qualifying attributes to describe the magnitude of potential consequences (e.g. low, medium and high) and the likelihood that those consequences will occur. An advantage of qualitative analysis is its ease of understanding by all relevant personnel while a disadvantage is the dependence on subjective choice of the scale.

These scales can be adapted or adjusted to suit the circumstances and different descriptions can be used for different risks. Qualitative risk analysis can be used:

- as an initial screening activity to identify risks that require more detailed analysis;
- where this kind of analysis is appropriate for decisions;
- where the numerical data or resources are inadequate for a quantitative risk analysis.

Qualitative analysis should use factual information and data where available.

b) Quantitative risk analysis:

Quantitative risk analysis uses a scale with numerical values (rather than the descriptive scales used in qualitative risk analysis) for both consequences and likelihood, using data from a variety of sources. The quality of the analysis depends on the accuracy and completeness of the numerical values and the validity of the models used. Quantitative risk analysis, in most cases, uses historical incident data, providing the advantage that it can be related directly to the information security objectives and concerns of the organization. A disadvantage is the lack of such data on new risks or information security weaknesses. A disadvantage of the quantitative approach can occur where factual, auditable data is not available, thus creating an illusion of worth and accuracy of the risk assessment.

The way in which consequences and likelihood are expressed and the ways in which they are combined to provide a level of risk will vary according to the type of risk and the purpose for which the risk assessment output is to be used. The uncertainty and variability of both consequences and likelihood should be considered in the analysis and communicated effectively.

8.3.2 Assessment of consequences

Input: A list of identified relevant incident scenarios, including identification of threats, vulnerabilities, affected assets, consequences to assets and business processes.

Action: The business impact on the organization that can result from possible or actual information security incidents should be assessed, taking into account the consequences of a breach of information security such as loss of confidentiality, integrity or availability of the assets.

Implementation guidance: After identifying all assets under review, values assigned to these assets should be taken into account while assessing the consequences.

A business impact concept is used to measure consequences. The business impact value can be expressed in qualitative and quantitative forms, but any method of assigning monetary value can generally provide more information for decision making and, hence, facilitate a more efficient decision-making process.

Asset valuation begins with the classification of assets according to their criticality, in terms of their importance to fulfilling the business objectives of the organization. Valuation is then determined using two measures:

- the replacement value of the asset: the cost of recovery clean-up and replacing the information (if at all possible);
- the business consequences of loss or compromise of the asset, such as the potential adverse business and/or legal or regulatory consequences from the disclosure, modification, non-availability and/or destruction of information, and other information assets.

This valuation can be determined from a business impact analysis. The value, determined by the consequence for business, is usually significantly higher than the simple replacement cost, depending on the importance of the asset to the organization in meeting its business objectives.

Asset valuation is a key factor in the impact assessment of an incident scenario, because the incident can affect more than one asset (e.g. dependent assets), or only a part of an asset. Different threats and vulnerabilities have different impacts on assets, such as a loss of confidentiality, integrity or availability. Assessment of consequences is thus related to asset valuation based on the business impact analysis.

Consequences or business impact can be determined by modelling the outcomes of an event or set of events, or by extrapolation from experimental studies or past data.

Consequences can be expressed in terms of monetary, technical or human impact criteria, or other criteria relevant to the organization. In some cases, more than one numerical value is required to specify consequences for different times, places, groups or situations.

Consequences in time and finance should be measured with the same approach used for threat likelihood and vulnerability. Consistency is to be maintained on the quantitative or the qualitative approach.

More information both on asset valuation and impact assessment can be found in [Annex B](#).

Output: A list of assessed consequences of an incident scenario expressed with respect to assets and impact criteria.

8.3.3 Assessment of incident likelihood

Input: A list of identified relevant incident scenarios, including identification of threats, affected assets, exploited vulnerabilities and consequences to assets and business processes. Also, lists of all existing and planned controls, their effectiveness, implementation and usage status.

Action: The likelihood of the incident scenarios should be assessed.

Implementation guidance:

After identifying the incident scenarios, it is necessary to assess the likelihood of each scenario and impact occurring, using qualitative or quantitative analysis techniques. This should take account of how often the threats occur and how easily the vulnerabilities can be exploited, considering:

- experience and applicable statistics for threat likelihood;
- for deliberate threat sources: the motivation and capabilities, which change over time, and resources available to possible attackers, as well as the perception of attractiveness and vulnerability of assets for a possible attacker;
- for accidental threat sources: geographical factors, e.g. proximity to chemical or petroleum plants, the possibility of extreme weather conditions, and factors that can influence human errors and equipment malfunction;
- vulnerabilities, both individually and in aggregation;

- existing controls and how effectively they reduce vulnerabilities.

For instance, an information system can have a vulnerability to the threats of masquerading of user identity and misuse of resources. The vulnerability of masquerading of user identity can be high because of lack of user authentication. On the other hand, the likelihood of misuse of resources can be low, despite lack of user authentication, because ways to misuse resources are limited.

Depending on the need for accuracy, assets can be grouped, or it can be necessary to split assets into their elements and relate the scenarios to the elements. For example, across geographical locations, the nature of threats to the same types of assets can change, or the effectiveness of existing controls can vary.

Output: Likelihood of incident scenarios (quantitative or qualitative).

8.3.4 Level of risk determination

Input: A list of incident scenarios with their consequences related to assets and business processes and their likelihood (quantitative or qualitative).

Action: The level of risk should be determined for all relevant incident scenarios.

Implementation guidance:

Risk analysis assigns values to the likelihood and the consequences of a risk. These values can be quantitative or qualitative. Risk analysis is based on assessed consequences and likelihood. Additionally, it can consider cost benefit, the concerns of stakeholders, and other variables, as appropriate for risk evaluation. The estimated risk is a combination of the likelihood of an incident scenario and its consequences.

Examples of different information security risk analysis methods or approaches can be found in [Annex E](#).

Output: A list of risks with value levels assigned.

8.4 Risk evaluation

Input: A list of risks with value levels assigned and risk evaluation criteria.

Action: Level of risks should be compared against risk evaluation criteria and risk acceptance criteria.

Implementation guidance:

The nature of the decisions pertaining to risk evaluation and risk evaluation criteria used to make those decisions, is decided when establishing the context. These decisions and the context should be revisited in more detail at this stage when more is known about the particular risks identified. To evaluate risks, organizations should compare the estimated risks (using selected methods or approaches as discussed in [Annex E](#)) with the risk evaluation criteria defined during the context establishment.

Risk evaluation criteria used to make decisions should be consistent with the defined external and internal information security risk management context and take into account the objectives of the organization and stakeholder views, etc. Decisions as taken in the risk evaluation activity are mainly based on the acceptable level of risk. However, consequences, likelihood, and the degree of confidence in the risk identification and analysis should be considered as well. Aggregation of multiple low or medium risks can result in much higher overall risks and should be addressed accordingly.

Considerations should include:

- *Information security properties*: if one criterion is not relevant for the organization (e.g. loss of confidentiality), then all risks impacting this criterion may not be relevant;

- *The importance of the business process or activity supported by a particular asset or set of assets: if the process is determined to be of low importance, risks associated with it should be given a lower consideration than risks that impact more important processes or activities;*

Risk evaluation uses the understanding of risk obtained by risk analysis to make decisions about future actions. Decisions should include:

- whether an activity should be undertaken;
- priorities for risk treatment considering estimated levels of risks.

Output: A list of risks prioritized according to risk evaluation criteria in relation to the incident scenarios that lead to those risks.

9 Information security risk treatment

9.1 General description of risk treatment

Input: A list of risks prioritized according to risk evaluation criteria in relation to the incident scenarios that lead to those risks.

Action: Controls to reduce, retain, avoid, or share the risks should be selected and a risk treatment plan defined.

Implementation guidance:

There are four options available for risk treatment: risk modification (see [9.2](#)), risk retention (see [9.3](#)), risk avoidance (see [9.4](#)) and risk sharing (see [9.5](#)).

[Figure 3](#) illustrates the risk treatment activity within the information security risk management process as presented in [Figure 2](#).

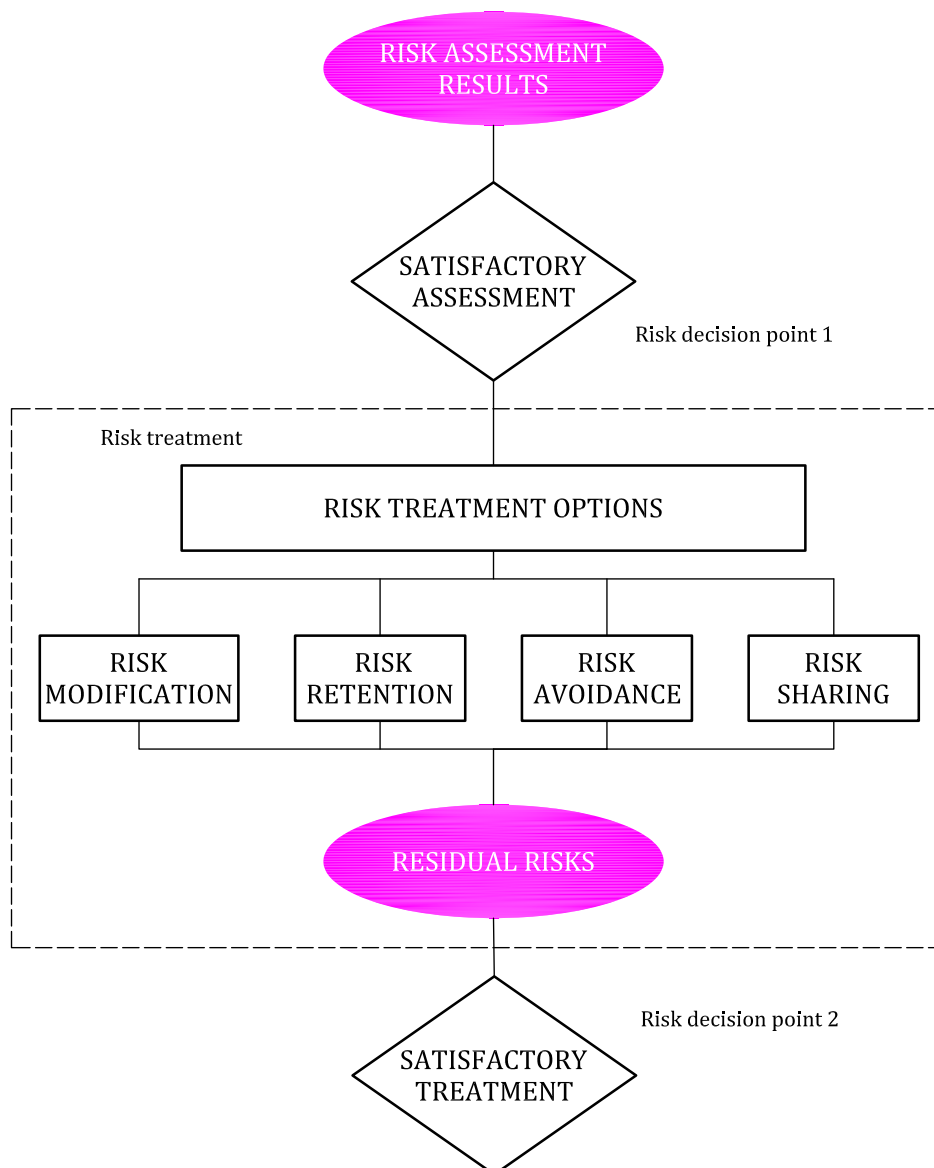


Figure 3 — The risk treatment activity

Risk treatment options should be selected based on the outcome of the risk assessment, the expected cost for implementing these options and the expected benefits from these options.

When large reductions in risks can be obtained with relatively low expenditure, such options should be implemented. Further options for improvements can be uneconomic and judgement needs to be exercised as to whether they are justifiable.

In general, the adverse consequences of risks should be made as low as reasonably practicable and irrespective of any absolute criteria. Managers should consider rare but severe risks. In such cases, it can be necessary to implement controls that are not justifiable on strictly economic grounds (for example, business continuity controls considered to cover specific high risks).

The four options for risk treatment are not mutually exclusive. Sometimes, the organization can benefit substantially by a combination of options such as reducing the likelihood of risks, reducing their consequences, and sharing or retaining any residual risks.

Some risk treatments can effectively address more than one risk (e.g. information security training and awareness). A risk treatment plan should be defined which clearly identifies the priority ordering in which individual risk treatments should be implemented and their timeframes. Priorities can

be established using various techniques, including risk ranking and cost-benefit analysis. It is the organization's managers' responsibility to decide the balance between the costs of implementing controls and the budget assignment.

The identification of existing controls can determine that existing controls exceed current needs, in terms of cost comparisons, including maintenance. If removing redundant or unnecessary controls is considered (especially if the controls have high maintenance costs), information security and cost factors should be taken into account. Since controls can influence each other, removing redundant controls can reduce the overall security in place. In addition, it can be cheaper to leave redundant or unnecessary controls in place than to remove them.

Risk treatment options should be considered taking into account:

- how risk is perceived by affected parties;
- the most appropriate ways to communicate to those parties.

The risk to organizations is failure to comply and treatment options to limit this possibility should be implemented. All constraints – organizational, technical, structural, etc. – that are identified during the context establishment activity should be taken into account during the risk treatment.

Once the risk treatment plan has been defined, residual risks need to be determined. This involves an update or re-iteration of the risk assessment, taking into account the expected effects of the proposed risk treatment. Should the residual risk still not meet the organization's risk acceptance criteria, a further iteration of risk treatment can be necessary before proceeding to risk acceptance.

Output: Risk treatment plan and residual risks subject to the acceptance decision of the organization's managers.

9.2 Risk modification

Action: The level of risk should be managed by introducing, removing or altering controls so that the residual risk can be reassessed as being acceptable.

Implementation guidance:

Appropriate and justified controls should be selected to meet the requirements identified by the risk assessment and risk treatment. This selection should also take account of cost and timeframe for implementation of controls, or technical, environmental and cultural aspects. It is often possible to lower the total cost of ownership of a system with properly selected information security controls.

In general, controls can provide one or more of the following types of protection: correction, elimination, prevention, impact minimization, deterrence, detection, recovery, monitoring and awareness. During control selection, it is important to weigh the cost of acquisition, implementation, administration, operation, monitoring, and maintenance of the controls against the value of the assets being protected. Furthermore, the return on investment in terms of risk reduction and potential to exploit new business opportunities afforded by certain controls should be considered. Additionally, consideration should be given to specialized skills that can be needed to define and implement new controls or modify existing ones.

ISO/IEC 27002 provides detailed information on controls.

There are many constraints that can affect the selection of controls. Technical constraints such as performance requirements, manageability (operational support requirements) and compatibility issues can hamper the use of certain controls or can induce human error either nullifying the control, giving a false sense of security or even increasing the risk beyond not having the control (e.g. requiring complex passwords without proper training, leading to users writing passwords down). Moreover, it can be that a control affects performance. Managers should try to identify a solution that satisfies performance requirements while guaranteeing sufficient information security. The result of this step is a list of possible controls, with their cost, benefit, and priority of implementation.

Various constraints should be taken into account when selecting controls and during implementation. Typically, the following are considered:

- time constraints;
- financial constraints;
- technical constraints;
- operational constraints;
- cultural constraints;
- ethical constraints;
- environmental constraints;
- ease of use;
- personnel constraints;
- constraints for integrating new and existing controls.

More information on the constraints for risk modification can be found in [Annex F](#).

9.3 Risk retention

Action: The decision on retaining the risk without further action should be taken depending on risk evaluation.

Implementation guidance:

If the level of risk meets the risk acceptance criteria, there is no need for implementing additional controls and the risk can be retained.

9.4 Risk avoidance

Action: The activity or condition that gives rise to the particular risk should be avoided.

Implementation guidance:

When the identified risks are considered too high, or the costs of implementing other risk treatment options exceed the benefits, a decision can be made to avoid the risk completely, by withdrawing from a planned or existing activity or set of activities, or changing the conditions under which the activity is operated. For example, for risks caused by nature it can be most cost-effective alternative to physically move the information processing facilities to a place where the risk does not exist or is under control.

9.5 Risk sharing

Action: The risk should be shared with another party that can most effectively manage the particular risk depending on risk evaluation.

Implementation guidance:

Risk sharing involves a decision to share certain risks with external parties. Risk sharing can create new risks or modify existing, identified risks. Therefore, additional risk treatment can be necessary.

Sharing can be done by an insurance that covers the consequences, or by sub-contracting a partner whose role is to monitor the information system and take immediate actions to stop an attack before it makes a defined level of damage.

It should be noted that it can be possible to share the responsibility to manage risk but it is not normally possible to share the liability of an impact. Customers usually attribute an adverse impact as being the fault of the organization.

10 Information security risk acceptance

Input: Risk treatment plan and residual risk assessment subject to the acceptance decision of the organization's managers.

Action: The decision to accept the risks and responsibilities for the decision should be made and formally recorded.

Implementation guidance:

Risk treatment plans should describe how assessed risks are to be treated to meet risk acceptance criteria (see 7.2). It is important for responsible managers to review and approve proposed risk treatment plans and resulting residual risks, and record any conditions associated with such approval.

Risk acceptance criteria can be more complex than just determining whether or not a residual risk falls above or below a single threshold.

In some cases, the level of residual risk does not meet risk acceptance criteria because the criteria being applied do not take into account prevailing circumstances. For example, it can be argued that it is necessary to accept risks because the benefits accompanying the risks are very attractive, or because the cost of risk modification is too high. Such circumstances indicate that risk acceptance criteria are inadequate and should be revised if possible. However, it is not always possible to revise the risk acceptance criteria in a timely manner. In such cases, decision-makers can accept risks that do not meet normal acceptance criteria. If this is necessary, the decision-maker should explicitly comment on the risks and include a justification for the decision to override normal risk acceptance criteria.

Output: A list of accepted risks with justification for those that do not meet the organization's normal risk acceptance criteria.

11 Information security risk communication and consultation

Input: All risk information obtained from the risk management activities (see Figure 2).

Action: Information about risk should be exchanged and/or shared between the decision-maker and other stakeholders.

Implementation guidance:

Risk communication is an activity to achieve agreement on how to manage risks by exchanging and/or sharing information about risk between the decision-makers and other stakeholders. The information includes, but is not limited to the existence, nature, form, likelihood, severity, treatment, and acceptability of risks.

Effective communication among stakeholders is important since this can have a significant impact on decisions to be made. Communication ensures that those responsible for implementing risk management, and those with a vested interest understand the basis on which decisions are made and why particular actions are required. Communication is bi-directional.

Perceptions of risk can vary due to differences in assumptions, concepts and the needs, issues and concerns of stakeholders as they relate to risk or the issues under discussion. Stakeholders are likely to make judgments on the acceptability of risk based on their perception of risk. This is especially important to ensure that the stakeholders' perceptions of risk, as well as their perceptions of benefits, can be identified and documented and the underlying reasons clearly understood and addressed.

Risk communication should be carried out in order to:

- provide assurance of the outcome of the organization's risk management;
- collect risk information;
- share the results from the risk assessment and present the risk treatment plan;
- avoid or reduce both occurrence and consequence of information security breaches due to the lack of mutual understanding among decision-makers and stakeholders;
- support decision making;
- obtain new information security knowledge;
- coordinate with other parties and plan responses to reduce consequences of any incident;
- give decision-makers and stakeholders a sense of responsibility about risks;
- improve awareness.

An organization should develop risk communication plans for normal operations as well as for emergency situations. Therefore, risk communication activity should be performed continually.

The coordination between major decision-makers and stakeholders can be achieved by the formation of a committee where debate about risks, their prioritization and appropriate treatment, and acceptance can take place.

It is important to cooperate with the appropriate public relations or communications unit within the organization to coordinate all tasks related to risk communication. This is crucial, in the event of crisis communication actions in response to particular incidents, for example.

Output: Continual understanding of the organization's information security risk management process and results.

12 Information security risk monitoring and review

12.1 Monitoring and review of risk factors

Input: All risk information obtained from the risk management activities (see [Figure 2](#)).

Action: Risks and their factors (i.e. value of assets, impacts, threats, vulnerabilities, likelihood of occurrence) should be monitored and reviewed to identify any changes in the context of the organization at an early stage, and to maintain an overview of the complete risk picture.

Implementation guidance:

Risks are not static. Threats, vulnerabilities, likelihood or consequences can change abruptly without any indication. Therefore, constant monitoring is necessary to detect these changes. This can be supported by external services that provide information regarding new threats or vulnerabilities.

Organizations should ensure that the following are continually monitored:

- new assets that have been included in the risk management scope;
- necessary modification of asset values, e.g. due to changed business requirements;
- new threats that can be active both outside and inside the organization and that have not been assessed;
- possibility that new or increased vulnerabilities can allow threats to exploit these new or changed vulnerabilities;

- identified vulnerabilities to determine those becoming exposed to new or re-emerging threats;
- increased impact or consequences of assessed threats, vulnerabilities and risks in aggregation resulting in an unacceptable level of risk;
- information security incidents.

New threats, vulnerabilities or changes in likelihood or consequences can increase risks previously assessed as low ones. Review of low and accepted risks should consider each risk separately, and all such risks as an aggregate as well, to assess their potential accumulated impact. If risks do not fall into the low or acceptable risk category, they should be treated using one or more of the options considered in [Clause 9](#).

Factors that affect the likelihood and consequences of threats occurring can change, as can factors that affect the suitability or cost of the various treatment options. Major changes affecting the organization should be reason for a more specific review. Therefore, the risk monitoring activities should be repeated regularly and the selected options for risk treatment should be reviewed periodically.

The outcome of risk monitoring activities can be input to other risk review activities. The organization should review all risks regularly, and when major changes occur.

Output: Continual alignment of the management of risks with the organization's business objectives, and with risk acceptance criteria.

12.2 Risk management monitoring, review and improvement

Input: All risk information obtained from the risk management activities (see [Figure 2](#)).

Action: The information security risk management process should be continually monitored, reviewed and improved as necessary and appropriate.

Implementation guidance:

Ongoing monitoring and review is necessary to ensure that the context, the outcome of the risk assessment and risk treatment, as well as management plans, remain relevant and appropriate to the circumstances.

The organization should make sure that the information security risk management process and related activities remain appropriate in the present circumstances and are followed. Any agreed improvements to the process or actions necessary to improve compliance with the process should be notified to the appropriate managers to have assurance that:

- no risk or risk element is overlooked or underestimated;
- the necessary actions are taken; and
- decisions are made to provide a realistic risk understanding and ability to respond.

Additionally, the organization should regularly verify that the criteria used to measure the risk and its elements are still valid and consistent with business objectives, strategies and policies. It should also regularly verify that changes to the business context are taken into consideration adequately during the information security risk management process. This monitoring and review activity should address (but not be limited to):

- competition context;
- risk assessment approach;
- asset value and categories;
- impact criteria;

- risk evaluation criteria;
- risk acceptance criteria;
- total cost of ownership;
- necessary resources.

The organization should ensure that risk assessment and risk treatment resources are continually available to review risk, to address new or changed threats or vulnerabilities, and to advise management accordingly.

Risk management monitoring can result in modifying or adding the approach, methodology or tools used depending on:

- changes identified;
- risk assessment iteration;
- aim of the information security risk management process (e.g. business continuity, resilience to incidents, compliance); and
- object of the information security risk management process (e.g. organization, business unit, information process, its technical implementation, application, connection to the Internet).

Output: Continual relevance of the information security risk management process to the organization's business objectives or updating the process.

Annex A (informative)

Defining the scope and boundaries of the information security risk management process

A.1 Study of the organization

Evaluate the organization: The study of the organization recalls the characteristic elements defining the identity of an organization. This concerns the purpose, business, missions, values and strategies of this organization. These should be identified together with the elements contributing to their development (e.g. subcontracting).

The difficulty of this activity lies in understanding exactly how the organization is structured. Identifying its real structure provides an understanding of the role and importance of each division in achieving the organization's objectives.

For example, the fact that the information security manager reports to the top managers rather than IT managers can indicate top managers' involvement in information security.

The organization's main purpose: The main purpose of an organization can be defined as the reason why it exists (its field of activity, its market segment, etc.).

Its business: The organization's business, defined by the techniques and know-how of its employees, enables it to accomplish its missions. It is specific to the organization's field of activity and often defines its culture.

Its mission: The organization achieves its purpose by accomplishing its mission. To identify its missions, the services provided and/or products manufactured should be identified in relation to the end users.

Its values: Values are major principles or a well-defined code of conduct applied to the exercise of a business. This can concern the personnel, relations with outside agents (customers, etc.), the quality of products supplied or services provided.

For example, an organization whose purpose is public service, whose business is transport and whose missions include transporting children to and from school can have punctuality of the service and safety during transport as its values.

Structure of the organization: There are different types of structure.

- Divisional structure: each division is placed under the authority of a division manager responsible for the strategic, administrative and operational decisions concerning his unit.
- Functional structure: functional authority is exercised on the procedures, the nature of the work and sometimes the decisions or planning (e.g. production, IT, human resources, marketing, etc.).

Remarks:

- A division within an organization with divisional structure can be organized as a functional structure and vice-versa.
- An organization can be said to have a matrix structure if it has elements of both types of structure.
- In any organizational structure, the following levels can be distinguished:
 - the decision-making level (definition of strategic orientations);

- the leadership level (coordination and management);
- the operational level (production and support activities).

Organization chart: The organization's structure is represented schematically in an organization chart. This representation should highlight the lines of reporting and delegation of authority, but should also include other relationships, which, even if they are not based on any formal authority, are nevertheless lines of information flow.

The organization's strategy: This requires a formal expression of the organization's guiding principles. The organization's strategy determines the direction and development needed in order to benefit from the issues at stake and of the major changes it is planning.

A.2 List of the constraints affecting the organization

All the constraints affecting the organization and determining its information security orientation should be taken into account. Their source can be within the organization (in which case it has some control over them) or outside the organization and, therefore, generally non-negotiable. Resource constraints (budget, personnel) and emergency constraints are among the most important ones.

The organization sets its objectives (concerning its business, behaviour, etc.) committing it to a certain path, possibly over a long period. It defines what it wants to become and the means that need to be implemented. In specifying this path, the organization takes into account developments in techniques and know-how, the expressed wishes of users, customers, etc. This objective can be expressed in the form of operating or development strategies with the aim, for example, of cutting operating costs, improving quality of service, etc.

These strategies probably include information and the information system (IS), which assist in their application. Consequently, characteristics concerning the identity, mission and strategies of the organization are fundamental elements in the analysis of the problem since the breach of an information security aspect can result in rethinking these strategic objectives. In addition, it is essential that proposals for information security requirements remain consistent with the rules, uses and means in force in the organization.

The list of constraints includes but is not limited to:

- Constraints of a political nature: These can concern government administrations, public institutions or more generally any organization that applies government decisions. They are usually decisions concerning strategic or operational orientation made by a government division or decision-making body and should be applied.

For example, the computerization of invoices or administrative documents introduces information security problems.

- Constraints of a strategic nature: Constraints can arise from planned or possible changes to the organization's structures or orientation. They are expressed in the organization's strategic or operational plans.

For example, international cooperation in the sharing of sensitive information can necessitate agreements concerning secure exchange.

- Territorial constraints: The organization's structure and/or purpose can introduce specific constraints such as the distribution of sites over the entire territory or abroad.

Examples include postal services, embassies, banks, subsidiaries of a large industrial group, etc.

- Constraints arising from the economic and political climate: An organization's operation can be profoundly changed by specific events such as strikes or national and international crises.

For example, some services should be able to continue even during a serious crisis.

- Structural constraints: The nature of an organization's structure (divisional, functional or other) can lead to a specific information security policy and security organization adapted to the structure.

For example, an international structure should be able to reconcile security requirements specific to each country.
- Functional constraints: Functional constraints arise directly from the organization's general or specific missions.

For example, an organization that operates around the clock should ensure its resources are continuously available.
- Constraints concerning personnel: The nature of these constraints varies considerably. They are linked to: level of responsibility, recruitment, qualification, training, security awareness, motivation, availability, etc.

For example, the entire personnel of a defence organization should have authorization to handle highly confidential information.
- Constraints arising from the organization's calendar: These constraints can result from restructuring or setting up new policies imposing certain deadlines.

For example, the creation of a security division.
- Constraints related to methods: Methods appropriate to the organization's know-how need to be imposed for aspects such as project planning, specifications, development and so on.
- Constraints of a cultural nature: In some organizations, work habits or the main business have led to a specific "culture" within the organization, which can be incompatible with the security controls. This culture is the personnel's general reference framework and can be determined by many aspects, including education, instruction, professional experience, experience outside work, opinions, philosophy, beliefs, social status, etc.
- Budgetary constraints: The recommended security controls can sometimes have a very high cost. While it is not always appropriate to base security investments on cost-effectiveness, economic justification is generally required by the organization's financial department.

For example, in the private sector and some public organizations, the total cost of security controls should not exceed the cost of the potential consequences of the risks. Top management should therefore assess and take calculated risks if they want to avoid excessive security costs.

A.3 List of the constraints affecting the scope

By identifying the constraints, it is possible to list those that have an impact on the scope and determine which ones still need appropriate action. They are added to, and can possibly amend, the organization's constraints determined above. The following paragraphs present a non-exhaustive list of possible types of constraints.

Constraints arising from pre-existing processes

Application projects are not necessarily developed simultaneously. Some depend on pre-existing processes. Even though a process can be broken down into sub-processes, the process is not necessarily influenced by all the sub-processes of another process.

Technical constraints

Technical constraints, relating to infrastructure, generally arise from installed hardware and software, and rooms or sites housing the processes:

- files (requirements concerning organization, media management, management of access rules, etc.);

- general architecture (requirements concerning topology (centralised, distributed, client-server), physical architecture, etc.);
- application software (requirements concerning specific software design, market standards, etc.);
- package software (requirements concerning standards, level of evaluation, quality, compliance with norms, security, etc.);
- hardware (requirements concerning standards, quality, compliance with norms, etc.);
- communication networks (requirements concerning coverage, standards, capacity, reliability, etc.);
- building infrastructure (requirements concerning civil engineering, construction, high voltages, low voltages, etc.).

Financial constraints

The implementation of security controls is often restricted by the budget that the organization can commit. However, the financial constraint should still to be the last to be considered as the budget allocation for security can be negotiated on the basis of the security study.

Environmental constraints

Environmental constraints arise from the geographical or economic environment in which the processes are implemented: country, climate, natural risks, geographical situation, economic climate, etc.

Time constraints

The time required for implementing security controls should be considered in relation to the ability to upgrade the information system; if the implementation time is very long, the risks for which the control was designed can have changed. Time is a determining factor for selecting solutions and priorities.

Constraints related to methods

Methods appropriate to the organization's know-how should be used for project planning, specifications, development and so on.

Organizational constraints

Various constraints can follow from organizational requirements:

- operation (requirements concerning lead-times, supply of services, surveillance, monitoring, emergency plans, degraded operation, etc.);
- maintenance (requirements for incident troubleshooting, preventive actions, rapid correction, etc.);
- human resources management (requirements concerning operator and user training, qualification for posts such as system administrator or data administrator, etc.);
- administrative management (requirements concerning responsibilities, etc.);
- development management (requirements concerning development tools, computer-aided software engineering, acceptance plans, organization to be set up, etc.);
- management of external relations (requirements concerning organization of third-party relations, contracts, etc.).

Annex B **(informative)**

Identification and valuation of assets and impact assessment

B.1 Examples of asset identification

B.1.1 General

To perform asset valuation, an organization first needs to identify its assets (at an appropriate level of detail). Two kinds of assets can be distinguished:

- the primary assets:
 - business processes and activities;
 - information;
- the supporting assets (on which the primary elements of the scope rely) of all types:
 - hardware;
 - software;
 - network;
 - personnel;
 - site;
 - organization's structure.

B.1.2 The identification of primary assets

To describe the scope more accurately, this activity consists in identifying the primary assets (business processes and activities, information). This identification is carried out by a mixed work group representative of the process (managers, information systems specialists and users).

The primary assets are usually the core processes and information of the activity in the scope. Other primary assets such as the organization's processes can also be considered, which are more appropriate for drawing up an information security policy or a business continuity plan. Depending on the purpose, some studies do not require an exhaustive analysis of all the elements making up the scope. In such cases, the study boundaries can be limited to the key elements of the scope.

Primary assets are of two types:

- 1) Business processes (or sub-processes) and activities, for example:
 - processes whose loss or degradation make it impossible to carry out the mission of the organization;
 - processes that contain secret processes or processes involving proprietary technology;
 - processes that, if modified, can greatly affect the accomplishment of the organization's mission;
 - processes that are necessary for the organization to comply with the applicable contractual, legal or regulatory requirements identified as per [Clause 6](#);

2) Information. More generally, primary information mainly comprises:

- vital information for the exercise of the organization's mission or business;
- personal information, as can be defined specifically in national laws regarding privacy;
- strategic information required for achieving objectives determined by the strategic orientations;
- high-cost information whose gathering, storage, processing and transmission require a long time and/or involve a high acquisition cost.

Processes and information that are not identified as sensitive after this activity have no defined classification in the remainder of the study. This means that, even if such processes or information are compromised, the organization can still accomplish the mission successfully.

However, they often inherit controls implemented to protect the processes and information identified as sensitive.

B.1.3 List and description of supporting assets

The scope consists of assets that should be identified and described. These assets have vulnerabilities that are exploitable by threats aiming to impair the primary assets of the scope (processes and information). They are of various types:

- Hardware. The hardware type consists of all the physical elements supporting processes.
 - Data processing equipment (active): Automatic information processing equipment including the items required to operate independently.
 - Transportable equipment: Portable computer equipment.
EXAMPLE Laptop computer, Personal Digital Assistant (PDA).
 - Fixed equipment: Computer equipment used on the organization's premises.
EXAMPLE Server, microcomputer used as a workstation.
 - Processing peripherals: Equipment connected to a computer via a communication port (serial, parallel link, etc.) for entering, conveying or transmitting data.
EXAMPLE Printer, removable disc drive.
 - Data medium (passive): These are media for storing data or functions.
 - Electronic medium: An information medium that can be connected to a computer or computer network for data storage. Despite their compact size, these media can contain a large amount of data. They can be used with standard computing equipment.
EXAMPLE Floppy disc, CD ROM, back-up cartridge, removable hard disc, memory key, tape.
 - Other media: Static, non-electronic media containing data.
EXAMPLE Paper, slide, transparency, documentation, fax.
- Software. Software consists of all the programmes contributing to the operation of a data processing set.
 - Operating system: This includes all the programmes of a computer making up the operational base from which all the other programmes (services or applications) are run. It includes a kernel and basic functions or services. Depending on the architecture, an operating system may be monolithic or made up of a micro-kernel and a set of system services. The main elements of the operating system are all the equipment management services (CPU, memory, disc, and network interfaces), task or process management services and user rights management services.

- Service, maintenance or administration software: Software characterized by the fact that it complements the operating system services and is not directly at the service of the users or applications (even though it is usually essential or even indispensable for the global operation of the information system).
- Package software or standard software: Standard software or package software are complete products commercialized as such (rather than one-off or specific developments) with medium, release and maintenance. They provide services for users and applications, but are not personalized or specific in the way that business applications are.

EXAMPLE Data base management software, electronic messaging software, groupware, directory software, web server software, etc.

- Business application:
 - Standard business application: This is commercial software designed to give users direct access to the services and functions they require from their information system in their professional context. There is a very wide, theoretically limitless, range of fields.

EXAMPLE Accounts software, machine tool control software, customer care software, personnel competency management software, administrative software, etc.

- Specific business application: This is software in which various aspects (primarily support, maintenance, upgrading, etc.) have been specifically developed to give users direct access to the services and functions they require from their information system. There is a very wide, theoretically unlimited, range of fields.

EXAMPLE Invoice management of telecom operators' customers, real time monitoring application for rocket launching.

- Network: The network type consists of all telecommunications devices used to interconnect several physically remote computers or elements of an information system.
 - Medium and supports: Communications and telecommunications media or equipment are characterized mainly by the physical and technical characteristics of the equipment (point-to-point, broadcast) and by the communication protocols (link or network – levels 2 and 3 of the OSI 7-layer model).

EXAMPLE Public Switching Telephone Network (PSTN), Ethernet, GigabitEthernet, Asymmetric Digital Subscriber Line (ADSL), wireless protocol specifications (e.g. WiFi 802.11), Bluetooth, FireWire.

- Passive or active relay: This sub-type includes all devices that are not the logical terminations of communications (IS vision) but are intermediate or relay devices. Relays are characterized by the supported network communication protocols. In addition to the basic relay, they often include routing and/or filtering functions and services, employing communication switches and routers with filters. They can often be administrated remotely and are usually capable of generating logs.

EXAMPLE Bridge, router, hub, switch, automatic exchange.

- Communication interface: The communication interfaces of the processing units are connected to the processing units but are characterized by the media and supported protocols, by any installed filtering, log or warning generation functions and their capacities and by the possibility and requirement of remote administration.

EXAMPLE General Packet Radio Service (GPRS), Ethernet adaptor.

- Personnel. The personnel type consists of all the groups of people involved in the information system.
 - Decision-maker: Decision-makers are the owners of the primary assets (information and functions) and the managers of the organization or specific project.

EXAMPLE Top management, project leader.

- Users: Users are the personnel who handle sensitive elements in the context of their activity and who have a special responsibility in this respect. They can have special access rights to the information system to carry out their everyday tasks.

EXAMPLE Human resources management, financial management, risk manager.

- Operation/maintenance staff: These are the personnel in charge of operating and maintaining the information system. They have special access rights to the information system to carry out their everyday tasks.

EXAMPLE System administrator, data administrator, back-up, Help Desk, application deployment operator, security officers.

- Developers: Developers are in charge of developing the organization's applications. They have access to part of the information system with high-level rights but do not take any action on the production data.

EXAMPLE Business application developers.

- Site. The site type comprises all the places containing the scope or part of the scope, and the physical means required for it to operate.

- Location:

- External environment: This concerns all locations in which the organization's means of security cannot be applied.

EXAMPLE Homes of the personnel, premises of another organization, environment outside the site (urban area, hazard area).

- Premises: This place is bounded by the organization's perimeter directly in contact with the outside. This can be a physical protective boundary obtained by creating physical barriers or means of surveillance around buildings.

EXAMPLE Establishment, buildings.

- Zone: A zone is formed by a physical protective boundary forming partitions within the organization's premises. It is obtained by creating physical barriers around the organization's information processing infrastructures.

EXAMPLE Offices, reserved access zone, secure zone.

- Essential services: All the services required for the organization's equipment to operate.

- Communication: Telecommunications services and equipment provided by an operator.

EXAMPLE Telephone line, PABX, internal telephone networks.

- Utilities:

- Services and means (sources and wiring) required for providing power to information technology equipment and peripherals.

EXAMPLE Low-voltage power supply, inverter, electrical circuit head-end.

- Water supply

- Waste disposal

- Services and means (equipment, control) for cooling and purifying the air.

EXAMPLE Chilled water pipes, air-conditioners.

- Organization. The organization type describes the organizational framework, consisting of all the personnel structures assigned to a task and the procedures controlling these structures.

- Authorities: These are organizations from which the studied organization derives its authority. They can be legally affiliated or external. This imposes constraints on the studied organization in terms of regulations, decisions and actions.

EXAMPLE Administrating body, Head office of an organization.

- Structure of the organization: This consists of the various branches of the organization, including its cross-functional activities, under the control of its management.

EXAMPLE Human resources management, IT management, purchasing management, business unit management, building safety service, fire service, audit management.

- Project or system organization: This concerns the organization set up for a specific project or service.

EXAMPLE New application development project, information system migration project.

- Subcontractors/suppliers/manufacturers: These are organizations that provide the organization with a service or resources and bound to it by contract.

EXAMPLE Facilities management company, outsourcing company, consultancy companies.

B.2 Asset valuation

B.2.1 General

The next step after asset identification is to agree on the scale to be used and the criteria for assigning a particular location on that scale to each asset, based on valuation. Because of the diversity of assets found within most organizations, it is likely that some assets that have a known monetary value is valued in the local unit of currency, while others which have a more qualitative value can be assigned a value ranging, for example, from “very low” to “very high”. The decision to use a quantitative scale or a qualitative scale is really a matter of organizational preference, but should be relevant to the assets being valued. Both valuation types can be used for the same asset.

Typical terms used for the qualitative valuation of assets include words such as: negligible, very low, low, medium, high, very high, and critical. The choice and range of terms suitable to an organization is strongly dependent on an organization's needs for security, organizational size, and other organization specific factors.

B.2.2 Criteria

The criteria used as the basis for assigning a value to each asset should be written out in unambiguous terms. This is often one of the most difficult aspects of asset valuation since the values of some assets may have to be subjectively determined and since many different individuals are likely to be making the determination. Possible criteria used to determine an asset's value include its original cost, its replacement or re-creation cost or its value can be abstract, e.g. the value of an organization's reputation.

Another basis for the valuation of assets is the costs incurred due to the loss of confidentiality, integrity and availability as the result of an incident. Non-repudiation, accountability, authenticity and reliability should also be considered, as appropriate. Such a valuation provides the important element dimensions to asset value, in addition to replacement cost, based on estimates of the adverse business consequences that would result from security incidents with an assumed set of circumstances. It is emphasized that this approach accounts for consequences that are necessary to factor into the risk assessment.

Many assets can have several values assigned to them during the course of valuation. For example, a business plan can be valued based on the labour expended to develop the plan, on the labour to input the data, and on its value to a competitor. The assigned values are most likely to differ considerably.

The assigned value can be the maximum of all possible values or the sum of some or all of the possible values. In the final analysis, it should be carefully determined which value or values are assigned to an asset since the final value assigned plays a role in the determination of the resources to be expended for the protection of the asset.

B.2.3 Reduction to the common base

Ultimately, all asset valuations need to be reduced to a common base. This can be done with criteria that can be used to assess the possible consequences resulting from a loss of confidentiality, integrity, availability, non-repudiation, accountability, authenticity, or reliability of assets, such as:

- impairment of business performance;
- loss of goodwill/negative effect on reputation;
- breach associated with personal information;
- endangerment of personal safety;
- adverse effects on law enforcement;
- breach of confidentiality;
- breach of public order;
- financial loss;
- disruption to business activities; and
- endangerment of environmental safety.

Another approach to assess the consequences can be:

- interruption of service: inability to provide the service;
- loss of customer confidence:
 - loss of credibility in the internal information system; and
 - damage to reputation;
- disruption of internal operation:
 - disruption in the organization itself; and
 - additional internal cost;
- disruption of a third party's operation:
 - disruption in third parties transacting with the organization; and
 - various types of injury;
- danger to personnel/user safety: danger for the organization's personnel and/or users;
- attack on users' private life;
- financial losses;
- financial costs for emergency or repair:
 - in terms of personnel;
 - in terms of equipment; and

- in terms of studies, experts' reports;
- loss of goods/funds/assets;
- loss of customers, loss of suppliers;
- judicial proceedings and penalties;
- loss of a competitive advantage;
- loss of technological/technical lead;
- loss of effectiveness/trust;
- loss of technical reputation;
- weakening of negotiating capacity;
- industrial crisis (strikes);
- government crisis;
- dismissal;
- material damage.

These criteria are examples of issues to be considered for asset valuation. For carrying out valuations, an organization needs to select criteria relevant to its type of business and security requirements. This can mean that some of the criteria listed above are not applicable, and that others can be added to the list.

B.2.4 Scale

After establishing the criteria to be considered, the organization should agree on a scale to be used organization-wide. The first step is to decide on the number of levels to be used. There are no rules with regard to the number of levels that are most appropriate. More levels provide a greater level of granularity but sometimes a too fine differentiation makes consistent assignments throughout the organization difficult. Normally, any number of levels between 3 (e.g. low, medium, and high) and 10 can be used as long as it is consistent with the approach the organization is using for the whole risk assessment process.

An organization can define its own limits for asset values, like “low”, “medium”, or “high”. These limits should be assessed according to the criteria selected (e.g. for possible financial loss, they should be given in monetary values, but for considerations such as endangerment of personal safety, monetary valuation can be complex and may not be appropriate for all organizations). Finally, it is entirely up to the organization to decide what is considered as being “low” or a “high” consequence. A consequence that can be disastrous for a small organization can be low or even negligible for a very large organization.

B.2.5 Dependencies

The more relevant and numerous the business processes supported by an asset, the greater the value of this asset. Dependencies of assets on business processes and other assets should be identified as well since this can influence the values of the assets. For example, the confidentiality of data should be kept throughout its life-cycle, at all stages, including storage and processing, i.e. the security needs of data storage and processing programmes should be directly related to the value representing the confidentiality of the data stored and processed. Also, if a business process is relying on the integrity of certain data being produced by a programme, the input data of this programme should be of appropriate reliability. Moreover, the integrity of information is dependent on the hardware and software used for its storage and processing. Also, the hardware is dependent on the power supply and possibly air conditioning. Thus, information about dependencies assists in the identification of threats and particularly vulnerabilities. Additionally, it helps to assure that the true value of the assets (through the dependency relationships) is given to the assets, thereby indicating the appropriate level of protection.

The values of assets on which other assets are dependent can be modified in the following way:

- if the values of the dependent assets (e.g. data) are lower or equal to the value of the asset considered (e.g. software), its value remains the same;
- if the values of the dependent asset (e.g. data) is greater, then the value of the asset considered (e.g. software) should be increased according to:
 - the degree of dependency; and
 - the values of the other assets.

An organization can have some assets that are available more than once, like copies of software programmes or the same type of computer used in most of the offices. It is important to consider this fact when doing the asset valuation. On one hand, these assets are overlooked easily. Therefore, care should be taken to identify all of them. On the other hand, they can be used to reduce availability problems.

B.2.6 Output

The final output of this step is a list of assets and their values relative to disclosure (preservation of confidentiality), modification (preservation of integrity, authenticity, non-repudiation and accountability), non-availability and destruction (preservation of availability and reliability), and replacement cost.

B.3 Impact assessment

An information security incident can impact more than one asset or only a part of an asset. Impact is related to the degree of success of the incident. As a consequence, there is an important difference between the asset value and the impact resulting from the incident. Impact is considered as having either an immediate (operational) effect or a future (business) effect that includes financial and market consequences.

Immediate (operational) impact is either direct or indirect.

1) Direct:

- a) the financial replacement value of lost (part of) asset;
- b) the cost of acquisition, configuration and installation of the new asset or back-up;
- c) the cost of suspended operations due to the incident until the service provided by the asset(s) is restored; and
- d) impact results in an information security breach.

2) Indirect:

- a) opportunity cost (financial resources needed to replace or repair an asset would have been used elsewhere);
- b) the cost of interrupted operations;
- c) potential misuse of information obtained through a security breach;
- d) violation of statutory or regulatory obligations; and
- e) violation of ethical codes of conduct.

As such, the first assessment (with no controls of any kind) estimates an impact as very close to the (combination of the) concerned asset value(s). For any next iteration for this (these) asset(s), the impact

is different (normally much lower) due to the presence and the effectiveness of the implemented controls.

Annex C

(informative)

Examples of typical threats

The following table gives examples of typical threats. The list can be used during the threat assessment process. Threats can be deliberate, accidental or environmental (natural) and result, for example, in damage or loss of essential services. The following list indicates for each threat type where D (deliberate), A (accidental), E (environmental) is relevant. D is used for all deliberate actions aimed at information assets, A is used for all human actions that can accidentally damage information assets, and E is used for all incidents that are not based on human actions. The groups of threats are not in priority order.

Type	Threats	Origin
Physical damage	Fire	A, D, E
	Water damage	A, D, E
	Pollution	A, D, E
	Major accident	A, D, E
	Destruction of equipment or media	A, D, E
	Dust, corrosion, freezing	A, D, E
Natural events	Climatic phenomenon	E
	Seismic phenomenon	E
	Volcanic phenomenon	E
	Meteorological phenomenon	E
	Flood	E
Loss of essential services	Failure of air-conditioning or water supply system	A, D
	Loss of power supply	A, D, E
	Failure of telecommunication equipment	A, D
Disturbance due to radiation	Electromagnetic radiation	A, D, E
	Thermal radiation	A, D, E
	Electromagnetic pulses	A, D, E
Compromise of information	Interception of compromising interference signals	D
	Remote spying	D
	Eavesdropping	D
	Theft of media or documents	D
	Theft of equipment	D
	Retrieval of recycled or discarded media	D
	Disclosure	A, D
	Data from untrustworthy sources	A, D
	Tampering with hardware	D
	Tampering with software	A, D
	Position detection	D

Type	Threats	Origin
Technical failures	Equipment failure	A
	Equipment malfunction	A
	Saturation of the information system	A, D
	Software malfunction	A
	Breach of information system maintainability	A, D
Unauthorized actions	Unauthorized use of equipment	D
	Fraudulent copying of software	D
	Use of counterfeit or copied software	A, D
	Corruption of data	D
	Illegal processing of data	D
Compromise of functions	Error in use	A
	Abuse of rights	A, D
	Forging of rights	D
	Denial of actions	D
	Breach of personnel availability	A, D, E

Particular attention should be paid to human threat sources. These are specifically itemized in the following table:

Origin of threat	Motivation	Possible consequences
Hacker, cracker	Challenge Ego Rebellion Status Money	— Hacking — Social engineering — System intrusion, break-ins — Unauthorized system access
Computer criminal	Destruction of information Illegal information disclosure Monetary gain Unauthorized data alteration	— Computer crime (e.g. cyber stalking) — Fraudulent act (e.g. replay, impersonation, interception) — Information bribery — Spoofing — System intrusion
Terrorist	Blackmail Destruction Exploitation Revenge Political gain Media coverage	— Bomb/terrorism — Information warfare — System attack (e.g. distributed denial of service) — System penetration — System tampering
Industrial espionage (Intelligence, companies, foreign governments, other government interests)	Competitive advantage Economic espionage	— Defence advantage — Political advantage — Economic exploitation — Information theft — Intrusion on personal privacy — Social engineering — System penetration — Unauthorized system access (access to classified, proprietary, and/or technology-related information)

Origin of threat	Motivation	Possible consequences
Insiders (poorly trained, disgruntled, malicious, negligent, dishonest, or terminated employees)	Curiosity Ego Intelligence Monetary gain Revenge Unintentional errors and omissions (e.g. data entry error, programming error)	— Assault on an employee — Blackmail — Browsing of proprietary information — Computer abuse — Fraud and theft — Information bribery — Input of falsified, corrupted data — Interception — Malicious code (e.g. virus, logic bomb, Trojan horse) — Sale of personal information — System bugs — System intrusion — System sabotage — Unauthorized system access

Annex D (informative)

Vulnerabilities and methods for vulnerability assessment

D.1 Examples of vulnerabilities

The following table gives examples for vulnerabilities in various security areas, including examples of threats that can exploit these vulnerabilities. The lists can provide help during the assessment of threats and vulnerabilities, to determine relevant incident scenarios. It is emphasized that in some cases other threats can exploit these vulnerabilities as well.

Types	Examples of vulnerabilities	Examples of threats
Hardware	Insufficient maintenance/faulty installation of storage media	Breach of information system maintainability
	Lack of periodic replacement schemes	Destruction of equipment or media
	Susceptibility to humidity, dust, soiling	Dust, corrosion, freezing
	Sensitivity to electromagnetic radiation	Electromagnetic radiation
	Lack of efficient configuration change control	Error in use
	Susceptibility to voltage variations	Loss of power supply
	Susceptibility to temperature variations	Meteorological phenomenon
	Unprotected storage	Theft of media or documents
	Lack of care at disposal	Theft of media or documents
	Uncontrolled copying	Theft of media or documents
Software	No or insufficient software testing	Abuse of rights
	Well-known flaws in the software	Abuse of rights
	No “logout” when leaving the workstation	Abuse of rights
	Disposal or reuse of storage media without proper erasure	Abuse of rights
	Lack of audit trail	Abuse of rights
	Wrong allocation of access rights	Abuse of rights
	Widely-distributed software	Corruption of data
	Applying application programs to the wrong data in terms of time	Corruption of data
	Complicated user interface	Error in use
	Lack of documentation	Error in use
	Incorrect parameter set up	Error in use
	Incorrect dates	Error in use

Types	Examples of vulnerabilities	Examples of threats
	Lack of identification and authentication mechanisms like user authentication	Forging of rights
	Unprotected password tables	Forging of rights
	Poor password management	Forging of rights
	Unnecessary services enabled	Illegal processing of data
	Immature or new software	Software malfunction
	Unclear or incomplete specifications for developers	Software malfunction
	Lack of effective change control	Software malfunction
	Uncontrolled downloading and use of software	Tampering with software
	Lack of back-up copies	Tampering with software
	Lack of physical protection of the building, doors and windows	Theft of media or documents
	Failure to produce management reports	Unauthorized use of equipment
Network	Lack of proof of sending or receiving a message	Denial of actions
	Unprotected communication lines	Eavesdropping
	Unprotected sensitive traffic	Eavesdropping
	Poor joint cabling	Failure of telecommunication equipment
	Single point of failure	Failure of telecommunication equipment
	Lack of identification and authentication of sender and receiver	Forging of rights
	Insecure network architecture	Remote spying
	Transfer of passwords in clear	Remote spying
	Inadequate network management (resilience of routing)	Saturation of the information system
	Unprotected public network connections	Unauthorized use of equipment
Personnel	Absence of personnel	Breach of personnel availability
	Inadequate recruitment procedures	Destruction of equipment or media
	Insufficient security training	Error in use
	Incorrect use of software and hardware	Error in use
	Lack of security awareness	Error in use
	Lack of monitoring mechanisms	Illegal processing of data
	Unsupervised work by outside or cleaning staff	Theft of media or documents
	Lack of policies for the correct use of telecommunications media and messaging	Unauthorized use of equipment
Site	Inadequate or careless use of physical access control to buildings and rooms	Destruction of equipment or media
	Location in an area susceptible to flood	Flood
	Unstable power grid	Loss of power supply
	Lack of physical protection of the building, doors and windows	Theft of equipment
	Lack of formal procedure for user registration and de-registration	Abuse of rights
	Lack of formal process for access right review (supervision)	Abuse of rights
	Lack or insufficient provisions (concerning security) in contracts with customers and/or third parties	Abuse of rights
	Lack of procedure of monitoring of information processing facilities	Abuse of rights

Types	Examples of vulnerabilities	Examples of threats
Organization	Lack of regular audits (supervision)	Abuse of rights
	Lack of procedures of risk identification and assessment	Abuse of rights
	Lack of fault reports recorded in administrator and operator logs	Abuse of rights
	Inadequate service maintenance response	Breach of information system maintainability
	Lack or insufficient Service Level Agreement	Breach of information system maintainability
	Lack of change control procedure	Breach of information system maintainability
	Lack of formal procedure for ISMS documentation control	Corruption of data
	Lack of formal procedure for ISMS record supervision	Corruption of data
	Lack of formal process for authorization of public available information	Data from untrustworthy sources
	Lack of proper allocation of information security responsibilities	Denial of actions
	Lack of continuity plans	Equipment failure
	Lack of e-mail usage policy	Error in use
	Lack of procedures for introducing software into operational systems	Error in use
	Lack of records in administrator and operator logs	Error in use
	Lack of procedures for classified information handling	Error in use
	Lack of information security responsibilities in job descriptions	Error in use
	Lack or insufficient provisions (concerning information security) in contracts with employees	Illegal processing of data
	Lack of defined disciplinary process in case of information security incident	Theft of equipment
	Lack of formal policy on mobile computer usage	Theft of equipment
	Lack of control of off-premise assets	Theft of equipment
	Lack or insufficient "clear desk and clear screen" policy	Theft of media or documents
	Lack of information processing facilities authorization	Theft of media or documents
	Lack of established monitoring mechanisms for security breaches	Theft of media or documents
	Lack of regular management reviews	Unauthorized use of equipment
	Lack of procedures for reporting security weaknesses	Unauthorized use of equipment
	Lack of procedures of provisions compliance with intellectual rights	Use of counterfeit or copied software

D.2 Methods for assessment of technical vulnerabilities

Proactive methods such as information system testing can be used to identify vulnerabilities depending on the criticality of the Information and Communications Technology (ICT) system and available resources (e.g. allocated funds, available technology, persons with the expertise to conduct the test). Test methods include:

- automated vulnerability scanning tool;

- security testing and evaluation;
- penetration testing; and
- code review.

The automated vulnerability scanning tool is used to scan a group of hosts or a network for known vulnerable services (e.g. system allows anonymous File Transfer Protocol (FTP), sendmail relaying). It should be noted, however, that some of the potential vulnerabilities identified by the automated scanning tool may not represent real vulnerabilities in the context of the system environment. For example, some of these scanning tools rate potential vulnerabilities without considering the site's environment and requirements. Some of the vulnerabilities flagged by the automated scanning software may actually not be vulnerable for a particular site but can be configured that way because their environment requires it. Thus, this test method can produce false positives.

Security testing and evaluation (STE) is another technique that can be used in identifying ICT system vulnerabilities during the risk assessment process. It includes the development and execution of a test plan (e.g. test script, test procedures, and expected test results). The purpose of system security testing is to test the effectiveness of the security controls of an ICT system as they have been applied in an operational environment. The objective is to ensure that the applied controls meet the approved security specification for the software and hardware and implement the organization's security policy or meet industry standards.

Penetration testing can be used to complement the review of security controls and ensure that different facets of the ICT system are secured. Penetration testing, when used in the risk assessment process, can be used to assess an ICT system's ability to withstand intentional attempts to circumvent system security. Its objective is to test the ICT system from the viewpoint of a threat source and to identify potential failures in the ICT system protection schemes.

Code review is the most thorough (but also most expensive) way of vulnerability assessment.

The results of these types of security testing will help identify a system's vulnerabilities.

It is important to note that penetration tools and techniques can give false results unless the vulnerability is successfully exploited. To exploit particular vulnerabilities one needs to know the exact system/application/patches setup on tested system. If those data are not known at the time of testing, it may not be possible to successfully exploit particular vulnerability (for example, gaining remote reverse shell); however, it is still possible to crash or restart a tested process or system. In such a case, the tested object should be considered vulnerable as well.

Methods may include the following activities:

- interview people and users;
- questionnaires;
- physical inspection;
- document analysis.

Annex E (informative)

Information security risk assessment approaches

E.1 High-level information security risk assessment

The high-level assessment allows definition of the priorities and chronology in the actions. For various reasons, such as budget, it may not be possible to implement all controls simultaneously and only the most critical risks can be addressed through the risk treatment process. As well, it can be premature to begin detailed risk management if implementation is only envisaged after one or two years. To reach this objective, the high-level assessment can begin with a high-level assessment of consequences instead of starting with a systematic analysis of threats, vulnerabilities, assets and consequences.

Another reason to start with the high-level assessment is to synchronize with other plans related to change management (or business continuity). For example, it is not sound to completely secure a system or application if it is planned to outsource it in the near future, although it can still be worth doing the risk assessment in order to define the outsource contract.

Features of the high-level risk assessment iteration can include the following:

- The high-level risk assessment can address a more global view of the organization and its information systems, considering the technology aspects as independent from the business issues. By doing this, the context analysis concentrates more on the business and operational environment than technological elements.
- The high-level risk assessment can address a more limited list of threats, and vulnerabilities grouped in defined domains or, to expedite the process, it can focus on risk or attack scenarios instead of their elements.
- Risks presented in a high-level risk assessment are frequently more general risk domains than specific identified risks. As the scenarios or the threats are grouped in domains, the risk treatment proposes lists of controls in this domain. The risk treatment activities try then first to propose and select common controls that are valid across the whole system.
- However, the high-level risk assessment, because it seldom addresses technology details, is more appropriate to provide organizational and non-technical controls and management aspects of technical controls, or key and common technical safeguards such as back-ups and anti-virus.

The advantages of a high-level risk assessment are as follows:

- The incorporation of an initial simple approach is likely to gain acceptance of the risk assessment programme.
- It should be possible to build a strategic picture of an organizational information security program, i.e. it acts as a good planning aid.
- Resources and money can be applied where they are most beneficial, and systems likely to be in the greatest need of protection will be addressed first.

As the initial risk analyses are at a high level, and potentially less accurate, the only potential disadvantage is that some business processes or systems may not be identified as requiring a second, detailed risk assessment. This can be avoided if there is adequate information on all aspects of the organization and its information and systems, including information gained from the evaluation of information security incidents.

The high-level risk assessment considers the business values of the information assets, and the risks from the organization's business point of view. At the first decision point (see [Figure 2](#)), several factors assist in determining whether the high-level assessment is adequate to treat risks; these factors can include the following:

- the business objectives to be achieved by using various information assets;
- the degree to which the organization's business depends on each information asset, i.e. whether functions that the organization considers critical to its survival or the effective conduct of business are dependent on each asset, or on the confidentiality, integrity, availability, non-repudiation, accountability, authenticity, and reliability of the information stored and processed on this asset;
- the level of investment in each information asset, in terms of developing, maintaining, or replacing the asset, and
- the information assets, for which the organization directly assigns value.

When these factors are assessed, the decision becomes easier. If the objectives of an asset are extremely important to an organization's conduct of business, or if the assets are at high risk, then a second iteration, the detailed risk assessment, should be conducted for the particular information asset (or part thereof).

A general rule to apply is: if the lack of information security can result in significant adverse consequences to an organization, its business processes or its assets, then a second iteration risk assessment, at more detailed level, is necessary to identify potential risks.

E.2 Detailed information security risk assessment

E.2.1 General

The detailed information security risk assessment process involves in-depth identification and valuation of assets, the assessment of threats to those assets, and assessment of vulnerabilities. The results from these activities are then used to assess the risks and then identify risk treatment.

The detailed step usually requires considerable time, effort and expertise, and can therefore be most suitable for information systems at high risk.

The final stage of the detailed information security risk assessment is to assess the overall risks, which is the focus of this annex.

Consequences can be assessed in several ways, including using quantitative, e.g. monetary, and qualitative measures (which can be based on the use of adjectives such as moderate or severe), or a combination of both. To assess the likelihood of threat occurrence, the timeframe over which the asset has value or needs to be protected should be established. The likelihood of a specific threat occurring is affected by the following:

- the attractiveness of the asset, or possible impact applicable when a deliberate human threat is being considered;
- the ease of conversion exploiting a vulnerability of the asset into reward, applicable if a deliberate human threat is being considered;
- the technical capabilities of the threat agent, applicable to deliberate human threats;
- the susceptibility of the vulnerability to exploitation, applicable to both technical and non-technical vulnerabilities.

Many methods make use of tables, and combine subjective and empirical measures. It is important that the organization uses a method with which it is comfortable, in which it has confidence, and that produces repeatable results. A few examples of table-based techniques are given below.

For additional guidance on techniques that can be used for detailed information security risk assessment, see IEC 31010.

The following examples use numbers to describe qualitative assessments. Users of these methods should be aware that it can be invalid to perform further mathematical operations using the numbers that are qualitative results produced by qualitative risk assessment methods.

E.2.2 Example 1 Matrix with predefined values

In risk assessment methods of this type, actual or proposed physical assets are valued in terms of replacement or reconstruction costs (i.e. quantitative measurements). These costs are then converted onto the same qualitative scale as that used for information (see below). Actual or proposed software assets are valued in the same way as physical assets, with purchase or reconstruction costs identified and then converted to the same qualitative scale as that used for information. Additionally, if any application software is found to have its own intrinsic requirements for confidentiality or integrity (for example if source code is itself commercially sensitive), it is valued in the same way as for information.

The values for information are obtained by interviewing selected business management (the “data owners”) who can speak authoritatively about the data, to determine the value and sensitivity of the data actually in use, or to be stored, processed or accessed. The interviews facilitate assessment of the value and sensitivity of the information in terms of the worst case scenarios that can be reasonably expected to happen from adverse business consequences due to unauthorized disclosure, unauthorized modification, non-availability for varying time periods, and destruction.

The valuation is accomplished using information valuation guidelines, which cover issues such as:

- personal safety;
- personal information and privacy;
- law enforcement;
- commercial and economic interests;
- financial loss/disruption of activities;
- public order;
- business policy and operations,
- loss of goodwill; and
- contract or agreement with a customer.

The guidelines facilitate identification of the values on a numeric scale, such as the 0 to 4 scale shown in the example matrix below, thus enabling the recognition of quantitative values where possible and logical, and qualitative values where quantitative values are not possible, e.g. for endangerment of human life.

The next major activity is the completion of pairs of questionnaires for each threat type, for each grouping of assets that a threat type relates to, to enable the assessment of the levels of threats (likelihood of occurrence) and levels of vulnerabilities (ease of exploitation by the threats to cause adverse consequences). Each question answer attracts a score. These scores are accumulated through a knowledge base and compared with ranges. This identifies threat levels on say a high to low scale and vulnerability levels similarly, as shown in the example matrix below, differentiating between the types of consequences as relevant. Information to complete the questionnaires should be gathered from interviews with appropriate technical, personnel and accommodation people, and physical location inspections, and reviews of documentation.

The asset values, and the threat and vulnerability levels, relevant to each type of consequence, are matched in a matrix such as that shown below, to identify for each combination the relevant measure of risk on a scale of 0 to 8. The values are placed in the matrix in a structured manner. An example is given below:

Table E.1

	Likelihood of occurrence — Threat	Low			Medium			High		
	Ease of Exploitation	L	M	H	L	M	H	L	M	H
Asset Value	0	0	1	2	1	2	3	2	3	4
	1	1	2	3	2	3	4	3	4	5
	2	2	3	4	3	4	5	4	5	6
	3	3	4	5	4	5	6	5	6	7
	4	4	5	6	5	6	7	6	7	8

For each asset, the relevant vulnerabilities and their corresponding threats are considered. If there is a vulnerability without a corresponding threat, or a threat without corresponding vulnerability, there is presently no risk (but care should be taken in case this situation changes). Now the appropriate row in the matrix is identified by the asset value, and the appropriate column is identified by the likelihood of the threat occurring and the ease of exploitation. For example, if the asset has the value 3, the threat is “high” and the vulnerability “low”, the measure of risk is 5. Assume an asset has a value of 2, e.g. for modification, the threat level is “low” and the ease of exploitation is “high”, then the measure of risk is 4. The size of the matrix, in terms of the number of threat likelihood categories, ease of exploitation categories and the number of asset valuation categories, can be adjusted to the needs of the organization. Additional columns and rows necessitate additional risk measures. The value of this approach is in ranking the risks to be addressed.

A similar matrix as shown in [Table E.2](#) results from the consideration of the likelihood of an incident scenario, mapped against the estimated business impact. The likelihood of an incident scenario is given by a threat exploiting a vulnerability with a certain likelihood. The table maps this likelihood against the business impact related to the incident scenario. The resulting risk is measured on a scale of 0 to 8 that can be evaluated against risk acceptance criteria. This risk scale can also be mapped to a simple overall risk rating, for example as:

- Low risk: 0 to 2;
- Medium risk: 3 to 5;
- High risk: 6 to 8.

Table E.2

	Likelihood of incident scenario	Very Low (Very unlikely)	Low (Unlikely)	Medium (Possible)	High (Likely)	Very High (Frequent)
Business Impact	Very low	0	1	2	3	4
	Low	1	2	3	4	5
	Medium	2	3	4	5	6
	High	3	4	5	6	7
	Very high	4	5	6	7	8

E.2.3 Example 2 — Ranking of Threats by Measures of Risk

A matrix or table such as that shown in [Table E.3](#) can be used to relate the factors of consequences (asset value) and likelihood of threat occurrence (taking account of vulnerability aspects). The first step is to evaluate the consequences (asset value) on a predefined scale, e.g. 1 through 5, of each threatened asset (column “b” in the table). The second step is to evaluate the likelihood of threat occurrence on a predefined scale, e.g. 1 through 5, of each threat (column “c” in the table). The third step is to calculate the measure of risk by multiplying (b × c). Finally, the threats can be ranked in order of their associated

measure of risk. Note that, in this example, 1 is taken as the lowest consequence and the lowest likelihood of occurrence.

Table E.3

Threat descriptor (a)	Consequence (asset) value (b)	Likelihood of threat occurrence (c)	Measure of risk (d)	Threat ranking (e)
Threat A	5	2	10	2
Threat B	2	4	8	3
Threat C	3	5	15	1
Threat D	1	3	3	5
Threat E	4	1	4	4
Threat F	2	4	8	3

As shown above, this is a procedure which permits different threats with differing consequences and likelihood of occurrence to be compared and ranked in order of priority, as shown here. In some instances, it is necessary to associate monetary values with the empirical scales used here.

E.2.4 Example 3 — Assessing a value for the likelihood and the possible consequences of risks

In this example, the emphasis is placed on the consequences of information security incidents (i.e. incident scenarios) and on determining which systems should be given priority. This is done by assessing two values for each asset and risk, which in combination will determine the score for each asset. When all the asset scores for the system are summed, a measure of risk to that system is determined.

First, a value is assigned to each asset. This value relates to the potential adverse consequences that can arise if the asset is threatened. For each applicable threat to the asset, this asset value is assigned to the asset.

Next, a likelihood value is assessed. This is assessed from a combination of the likelihood of the threat occurring and the ease of exploitation of the vulnerability, see [Table E.4](#) expressing the likelihood of an incident scenario.

Table E.4

Likelihood of Threat	Low			Medium			High		
Levels of Vulnerability	L	M	H	L	M	H	L	M	H
Likelihood Value of an incident scenario	0	1	2	1	2	3	2	3	4

Next, an asset/threat score is assigned by finding the intersection of asset value and likelihood value in [Table E.5](#). The asset/threat scores are totalled to produce an asset total score. This figure can be used to differentiate between the assets forming part of a system.

Table E.5

Asset value	0	1	2	3	4
Likelihood value					
0	0	1	2	3	4
1	1	2	3	4	5
2	2	3	4	5	6
3	3	4	5	6	7
4	4	5	6	7	8

The final step is to total all the asset total scores for the assets of the system, producing a system score. This can be used to differentiate between systems and to determine which system's protection should be given priority.

In the following examples, all values are randomly chosen.

Suppose System S has three assets A1, A2 and A3. Also suppose there are two threats T1 and T2 applicable to system S. Let the value of A1 be 3. Similarly, let the asset value of A2 be 2 and the asset value of A3 be 4.

If, for A1 and T1, the threat likelihood is low and the ease of exploitation of the vulnerability is medium, then the likelihood value is 1 (see [Table E.4](#)).

The asset/threat score A1/T1 can be derived from [Table E.5](#) as the intersection of asset value 3 and likelihood value 1, i.e. 4. Similarly, for A1/T2 let the threat likelihood is medium and the ease of exploitation of vulnerability is high, giving an A1/T2 score of 6.

Now the total asset score A1T can be calculated, i.e. 10. The total asset score is calculated for each asset and applicable threat. The total system score is calculated by adding A1T + A2T + A3T to give ST.

Now different systems can be compared to establish priorities and different assets within one system as well.

The example above shows in terms of information systems. However, similar approaches can be applied to business processes.

Annex F (informative)

Constraints for risk modification

While considering constraints for risk modification, the following constraints should be taken into account:

— Time constraints:

Many types of time constraints can exist. For example, controls should be implemented within a time period acceptable for the organization's managers. Another type of time constraint is whether a control can be implemented within the lifetime of the information or system. A third type of time constraint can be the period of time the organization's managers decides is an acceptable period to be exposed to a particular risk.

— Financial constraints:

Controls should not be more expensive to implement or to maintain than the value of risks they are designed to protect. Every effort should be made not to exceed assigned budgets and achieve financial advantage through the use of controls. However, in some cases, it may not be possible to achieve the desired security and level of risk acceptance due to budget constraints. This therefore becomes an organization's managers' decision for resolution of this situation.

Great care should be taken if the budget reduces the number or quality of controls to be implemented since this can lead to the implicit retention of greater risk than planned. The established budget for controls should only be used as a limiting factor with considerable care.

— Technical constraints:

Technical problems, like the compatibility of programmes or hardware, can easily be avoided if they are taken into account during the selection of controls. In addition, the retrospective implementation of controls to an existing process or system is often hindered by technical constraints. These difficulties can move the balance of controls towards the procedural and physical aspects of security. It can be necessary to revise the information security programme in order to achieve security objectives. This can occur when controls do not meet the expected results in reducing risks without lessening productivity.

— Operational constraints

Operational constraints such as the need to operate 24/7 yet still perform back-ups can result in complex and costly implementation of controls unless they are built into the design right from the start.

— Cultural constraints:

Cultural constraints to the selection of controls may be specific to a country, a sector, an organization or even a department within an organization. Not all controls can be applied in all countries. For example, it can be possible to implement bag searches in parts of Europe but not in parts of the Middle East. Cultural aspects cannot be ignored because many controls rely on the active support of the staff. If the staff does not understand the need for the control or do not find it culturally acceptable, the control becomes ineffective over time.

— Ethical constraints:

Ethical constraints can have major implications on controls as ethics change based on social norms. This can prevent implementing controls such as e-mail scanning in some countries. Privacy

of information can also change dependent on the ethics of the region or government. These can be of more concern in some industry sectors than others, for example, government and healthcare.

— Environmental constraints:

Environmental factors can influence the selection of controls, such as space availability, extreme climate conditions, surrounding natural and urban geography. For example, earthquake proofing can be required in some countries but unnecessary in others.

— Ease of use:

A poor human-technology interface results in human error and can render the control useless. Controls should be selected to provide optimal ease of use while achieving an acceptable level of residual risk to the business. Controls that are difficult to use impact their effectiveness, as users can try to circumvent or ignore them as much as possible. Complex access controls within an organization can encourage users to find alternate, unauthorized methods of access.

— Personnel constraints:

The availability and salary cost of specialized skill sets to implement controls, and the ability to move staff between locations in adverse operating conditions, should be considered. Expertise may not be readily available to implement planned controls or the expertise can be overly costly for the organization. Other aspects, such as the tendency of some staff to discriminate other staff members who are not security screened, can have major implications for security policies and practices. As well, the need to hire the right people for the work, and finding the right people, can result in hiring before security screening is completed. The requirement for security screening to be completed before hiring is the normal, and safest, practice.

— Constraints of integrating new and existing controls:

Integration of new controls in the existing infrastructure and the interdependencies between controls are often overlooked. New controls may not easily be implemented if there is incongruity or incompatibility with existing controls. For example, a plan to use biometric tokens for physical access control can cause conflict with an existing PIN-pad based system for access control. The cost of changing controls from existing controls to the planned controls should include elements to be added to the overall costs of risk treatment. It may not be possible to implement a selected control due to interference with current controls.

Bibliography

- [1] ISO/IEC Guide 73, *Risk management — Vocabulary*
- [2] ISO/IEC 16085, *Systems and software engineering — Life cycle processes — Risk management*
- [3] ISO/IEC 27001, *Information technology — Security techniques — Information security management systems — Requirements*
- [4] ISO/IEC 27002, *Information technology — Security techniques — Code of practice for information security controls*
- [5] ISO 31000, *Risk management — Principles and guidelines*
- [6] NIST Special Publication 800-12, *An Introduction to Computer Security: The NIST Handbook*
- [7] NIST Special Publication 800-30, *Risk Management Guide for Information Technology Systems, Recommendations of the National Institute of Standards and Technology*

